DOS SESIONES · 2,5 HORAS CADA UNA

# Analítica de procesos para ciberseguridad

Sesión 1 de 2 · De los datos al modelo

Laura Sandino Perdomo

APERTURA · EL OBJETIVO

# Qué van a poder hacer al terminar

PRÁCTICA 1

## Clasificar

Decidir si un incidente es real.

LA PREGUNTA

**¿Es una amenaza real?**

PRÁCTICA 2

## Reconstruir

Ver cómo se atiende de verdad un proceso.

LA PREGUNTA

**¿Se sigue el procedimiento? ¿Dónde espera?**

PRÁCTICA 3

## Agrupar

Juntar incidentes parecidos.

LA PREGUNTA

**¿Qué tipos de incidentes tengo?**

PRÁCTICA 4

## Detectar

Encontrar lo que se sale de lo normal.

LA PREGUNTA

**¿Qué se comporta de forma rara?**

Y MEDIR CON HONESTIDAD

Cualquiera puede construir un modelo que *parezca* bueno. La habilidad que más importa es saber si de verdad funciona.

APERTURA · FORMA DE TRABAJO

# Cómo vamos a trabajar

1
**Teoría corta**
Cada concepto en pocos minutos, con una analogía.

2
**Práctica en Colab**
Se ejecuta enseguida, con datos reales de incidentes.

3
**Discusión**
¿Qué significan los resultados para nuestro trabajo?

SIN INSTALAR NADA

Todo corre en el navegador, con una cuenta de Google.

SIN ESCRIBIR CÓDIGO DESDE CERO

Los cuadernos ya traen el código, comentado.

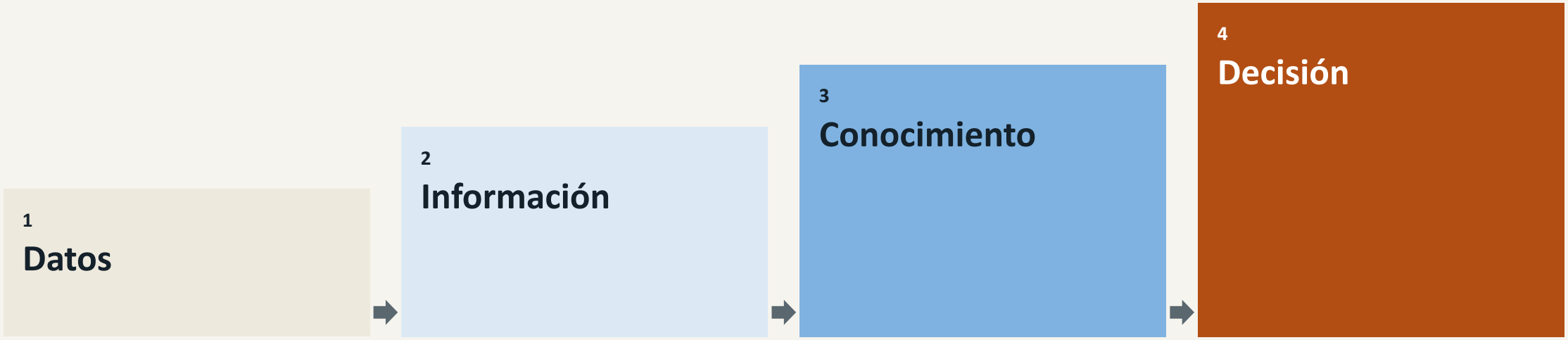
CADA PRÁCTICA, UNA PREGUNTA

Y un cierre: qué aprendimos y qué no.

PARA ABRIR UN CUADERNO

Enlace del repositorio → botón de Colab. Si Colab avisa que el cuaderno no es de Google: «Ejecutar de todos modos». Cada persona trabaja en su copia.

# Analítica: pasar de los datos a una decisión




LA IDEA

Una lista de 50.000 alertas no le dice nada a nadie. La analítica la convierte en algo que permite **decidir**.

MARCO · LOS CUATRO TIPOS

# Cuatro tipos de analítica, cuatro preguntas

| TIPO | PREGUNTA | EJEMPLO EN UN SOC |
|---|---|---|
| **Descriptiva** | ¿Qué pasó? | Cuántos incidentes hubo este mes y cuánto tardamos en resolverlos |
| **Diagnóstica** | ¿Por qué pasó? | Por qué se dispararon las alertas el martes |
| **Predictiva** | **¿Qué va a pasar?** | ¿Este incidente será una amenaza real? ¿Se cumplirá el plazo? |
| **Prescriptiva** | ¿Qué hago? | Qué acción de contención recomendar para este incidente |

ESTE CURSO

Trabaja sobre todo la **predictiva**, con un pie en la **diagnóstica** (la minería de procesos) y un vistazo a la **prescriptiva** al final. Cada nivel necesita el anterior.

MARCO · ANALÍTICA AUMENTADA

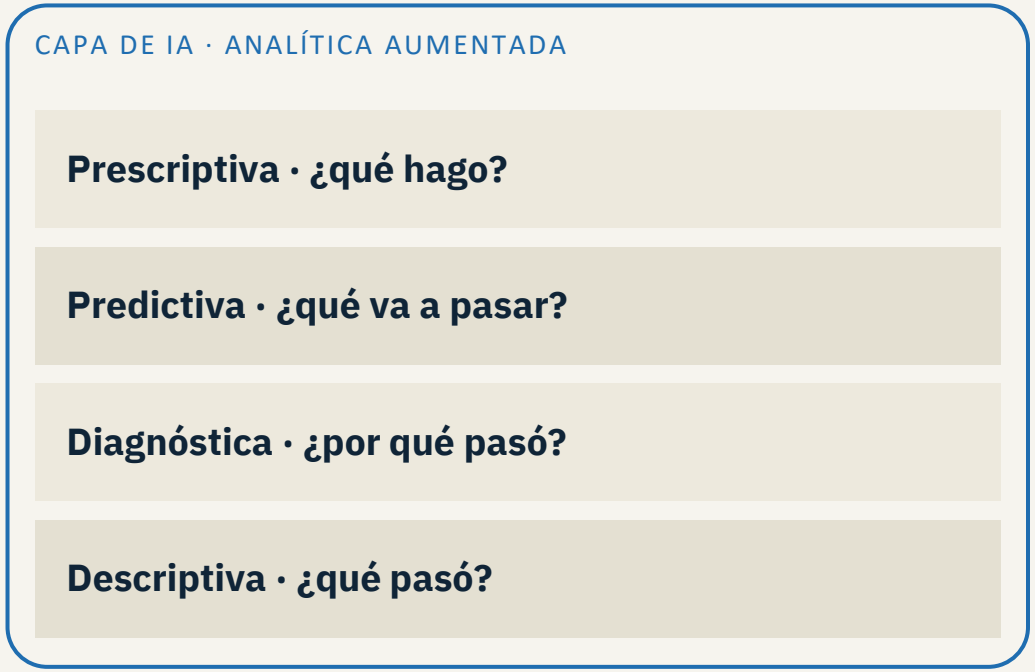
# La IA ayuda a hacer analítica: una capa, no un tipo

QUÉ ES

**Analítica aumentada** = usar IA para ayudar a preparar los datos, encontrar hallazgos y hacer consultas.

HOY

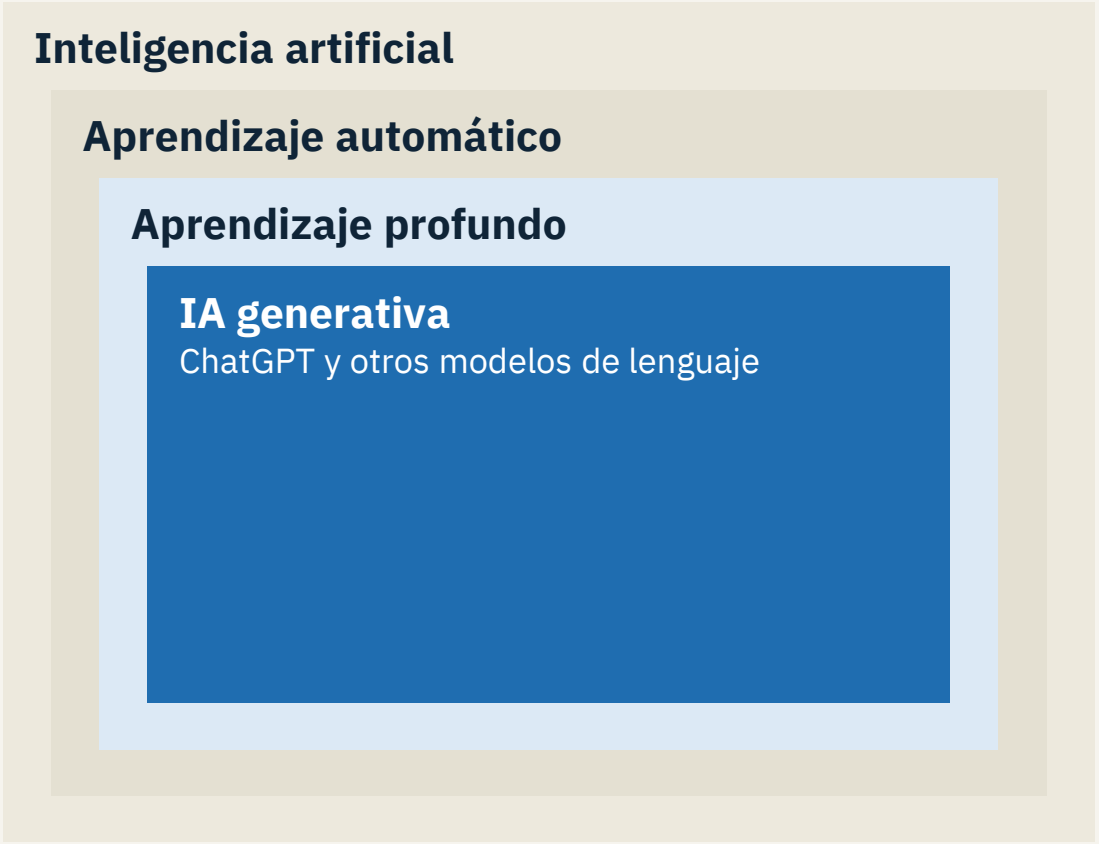
Asistentes que traducen una pregunta en lenguaje natural a una consulta (SPL, KQL, SQL).




CUIDADO

Ayuda, pero **no reemplaza** entender los datos: un asistente que se equivoca con total seguridad es peor que ninguno.

# IA, aprendizaje automático, profundo y generativa




INTELIGENCIA ARTIFICIAL

Que una máquina haga algo que parece inteligente.

APRENDIZAJE AUTOMÁTICO

Que **aprenda de ejemplos** en vez de seguir reglas escritas.

APRENDIZAJE PROFUNDO

Aprendizaje automático con **redes neuronales grandes**.

IA GENERATIVA

Modelos que **producen** texto, imágenes o código.

Todo lo de adentro es también lo de afuera.

MARCO · LOS DATOS

# Filas, columnas y la columna que queremos predecir

VARIABLES · LO QUE EL MODELO VE

VARIABLE OBJETIVO · LO QUE PREDECIMOS

| INCIDENTE | ALERTAS | EVIDENCIAS | DURACIÓN (MIN) | HORA DE INICIO | GRADO |
|---|---|---|---|---|---|
| **Incidente A** | 3 | 9 | 53,5 | 23 | **amenaza real** |
| **Incidente B** | 2 | 18 | 1.063 | 15 | **sin amenaza** |
| **Incidente C** | 1 | 35 | 0 | 18 | **actividad esperada** |
| **Incidente D** | 1 | 2 | 0 | 10 | **amenaza real** |

Filas reales de la muestra de GUIDE (incidentes de Microsoft). Una fila = un incidente · una columna = una variable.

NUMÉRICAS

Se pueden contar o medir: número de alertas, minutos.

CATEGÓRICAS

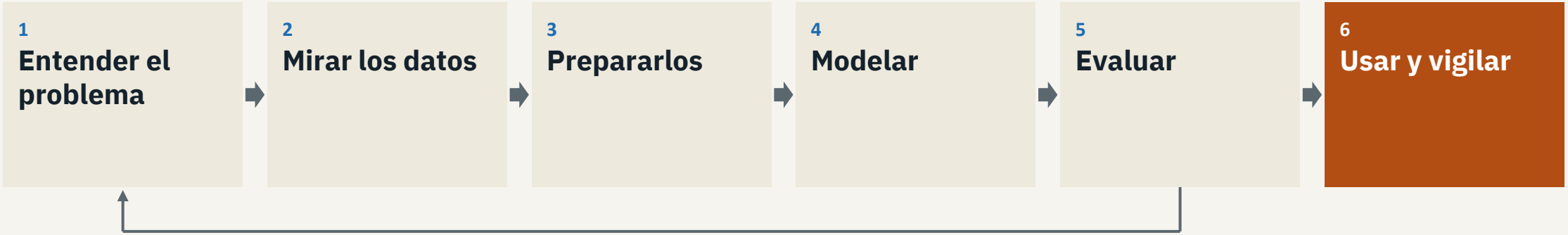
Son etiquetas: táctica de ataque, grupo de trabajo.

FECHAS

Se convierten en números útiles: hora del día, día de la semana.

MARCO · EL CICLO DE UN PROYECTO

# Todo proyecto de analítica sigue el mismo ciclo




Casi nunca se avanza en línea recta: evaluar suele mandarnos a entender mejor el problema.

PASO 6 · PONER EN PRODUCCIÓN Y MANTENER

Vigilar, detectar cuando el modelo envejece y reentrenar. A eso se le llama **MLOps** (*Machine Learning Operations*).

EN LAS PRÁCTICAS

Cada práctica recorre los pasos 1 a 5. El 6 lo vemos en la diapositiva 75.

EL SOC · LA ANALOGÍA

# Un SOC es la sala de urgencias de la seguridad

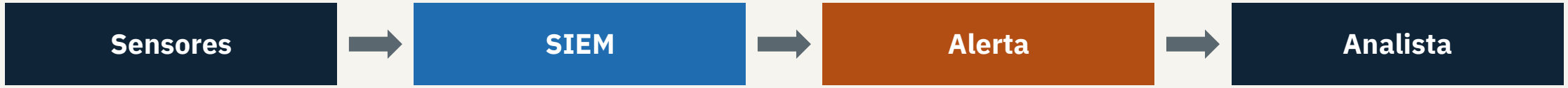
| URGENCIAS DE UN HOSPITAL | CENTRO DE OPERACIONES DE SEGURIDAD (SOC) |
|---|---|
| **Pacientes que llegan** | **Alertas** que llegan |
| **Triaje: ¿quién es grave?** | **Triaje**: ¿esto es real? |
| **Médicos y especialistas** | **Analistas** de distintos niveles |
| **Signos vitales** | **Registros** (logs) de equipos, red, nube y correo |
| **La mayoría de las visitas no son urgencias** | La mayoría de las alertas **no son ataques** |

SOC · SECURITY OPERATIONS CENTER

El equipo —con sus procesos y herramientas— que vigila los sistemas de una organización todo el día para detectar y responder a ataques.

# Las piezas de un SOC

| PIEZA | QUÉ HACE | EN URGENCIAS |
|---|---|---|
| **Telemetría (logs)** | Los registros que dejan computadores, red, nube, correo e identidades | Los signos vitales |
| **SIEM** | Reúne todos los registros y, con reglas o modelos, genera **alertas** | El monitor que pita |
| **EDR / NDR** | Un programa en cada equipo (o en la red) que vigila qué ejecuta o qué tráfico mueve | Los sensores de cada cama |
| **SOAR** | Automatiza pasos repetitivos de respuesta (*playbooks*) | Protocolos automáticos |
| **Analistas N1 / N2 / N3** | Clasifican alertas / investigan / cazan amenazas y mejoran las reglas | Enfermería de triaje / médicos / especialistas |




Muchos sensores, algo que los junta y personas que deciden: la analítica ocurre entre las alertas y las decisiones.

EL SOC · EL PROCESO

# El proceso de un incidente, de la alerta al aprendizaje

1
**Detectar**
Aparece una alerta

2
**Triaje**
¿Es real? ¿Qué tan grave?

3
**Investigar**
Juntar alertas relacionadas en un *incidente*

4
**Contener**
Aislar el equipo, revocar credenciales

5
**Recuperar**
Volver a la normalidad

6
**Aprender**
Ajustar las reglas

**MTTR** · tiempo medio hasta responder

**MTTD** · tiempo medio hasta detectar

POR ESO SE LLAMA «ANALÍTICA DE PROCESOS»

Un incidente es un **proceso**: pasos que se repiten, con tiempos y responsables. Deja una huella (cuándo se abrió, quién lo tuvo, cuánto esperó) que se puede analizar. Lo haremos en la Práctica 2.

EL SOC · EL VOCABULARIO

# Alerta, incidente y los tres resultados

**Alerta**: un aviso aislado. **Incidente**: varias alertas relacionadas que cuentan una historia.

VP

### Verdadero positivo

Es un ataque real.

Cuaderno: **amenaza real**

FP

### Falso positivo

Sonó la alarma, pero no pasó nada.

Cuaderno: **sin amenaza**

PB

### Positivo benigno

Pasó algo real, pero es esperado (una prueba de penetración autorizada).

Cuaderno: **actividad esperada**

FN

### Falso negativo

El ataque que **nadie vio**: el más peligroso.

Es un error del modelo, no una etiqueta.

FATIGA DE ALERTAS

Demasiadas falsas alarmas y el analista deja de creerle al sistema.

DATO REAL · GUIDE DE MICROSOFT

1 millón de incidentes de clientes reales:




Más de 8 de cada 10 incidentes **no eran ataques**.

EN LOS CUADERNOS

Para no confundirlos con los errores de un modelo, las tres etiquetas se llaman **amenaza real**, **sin amenaza** y **actividad esperada**.

EL SOC · EL MAPA DEL CURSO

# Cuatro problemas del SOC, cuatro prácticas

| PROBLEMA DEL SOC | TÉCNICA | PRÁCTICA |
|---|---|---|
| **¿Este incidente es real? (triaje)** | Clasificación | 1 |
| **¿Cómo se atiende de verdad un incidente y dónde se atasca?** | Minería de procesos | 2 |
| **¿Qué tipos de incidentes tengo?** | Segmentación | 3 |
| **¿Qué se sale de lo normal?** | Detección de anomalías | 4 |

SIGUE

Dos bloques de teoría —aprendizaje automático y evaluación— nos preparan para la Práctica 1.

ML · LA IDEA

# Aprender de ejemplos en vez de seguir reglas escritas

PROGRAMACIÓN CLÁSICA




Una persona escribe las reglas: «si el correo trae un enlace y dice *urgente*, es sospechoso». Los datos entran, las reglas deciden.

APRENDIZAJE AUTOMÁTICO



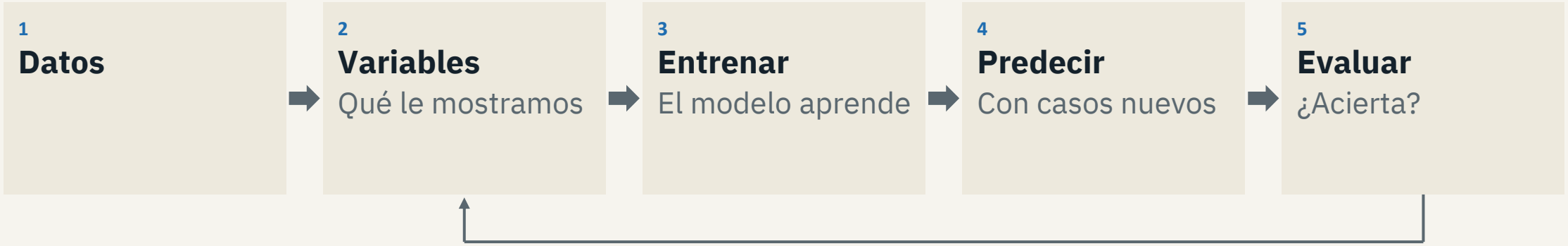

Se le dan **ejemplos con su respuesta** y el computador **encuentra las reglas por sí mismo**.

COMO UN ANALISTA JUNIOR

Nadie le da un manual con todas las reglas: ve miles de alertas que otros ya clasificaron y, con el tiempo, aprende a distinguir.

ML · EL CICLO DE UN MODELO

# Datos, variables, entrenar, predecir, evaluar




LO QUE DECIDE SI UN MODELO SIRVE

Entrenar suena a magia y es el paso más pequeño del ciclo. Casi todo depende de **qué variables le damos** y de **cómo lo evaluamos**.

ML · LO QUE VE EL MODELO

# Variables y etiqueta: una fila real de la Práctica 1

VARIABLES · LO QUE EL MODELO VE

| 3 | 9 | 53 | 2 | 0 % | 23 h |
|---|---|---|---|---|---|
| alertas | evidencias | minutos de duración | tácticas | veredicto «malicioso» | hora de inicio |

ETIQUETA

**amenaza real**

Fila real de la muestra de GUIDE (Microsoft).

EL MODELO NO VE EL INCIDENTE

Ve una lista de números que lo resumen. Si lo importante no está en esos números, el mejor modelo del mundo no lo va a encontrar. **Escoger y construir bien las variables es la mitad del trabajo.**

# Estudiar no es lo mismo que el examen

**70 % PARA ENTRENAR**

El modelo **ve** las respuestas y aprende de ellas.

**30 % PARA PROBAR**

Nunca las ve: solo las usamos para **calificarlo**.

REGLA 1

### La prueba no se toca

...hasta el final.

REGLA 2

### Semilla fija

Se sortea con una semilla para que todos obtengamos lo mismo.

REGLA 3

### Estratificar

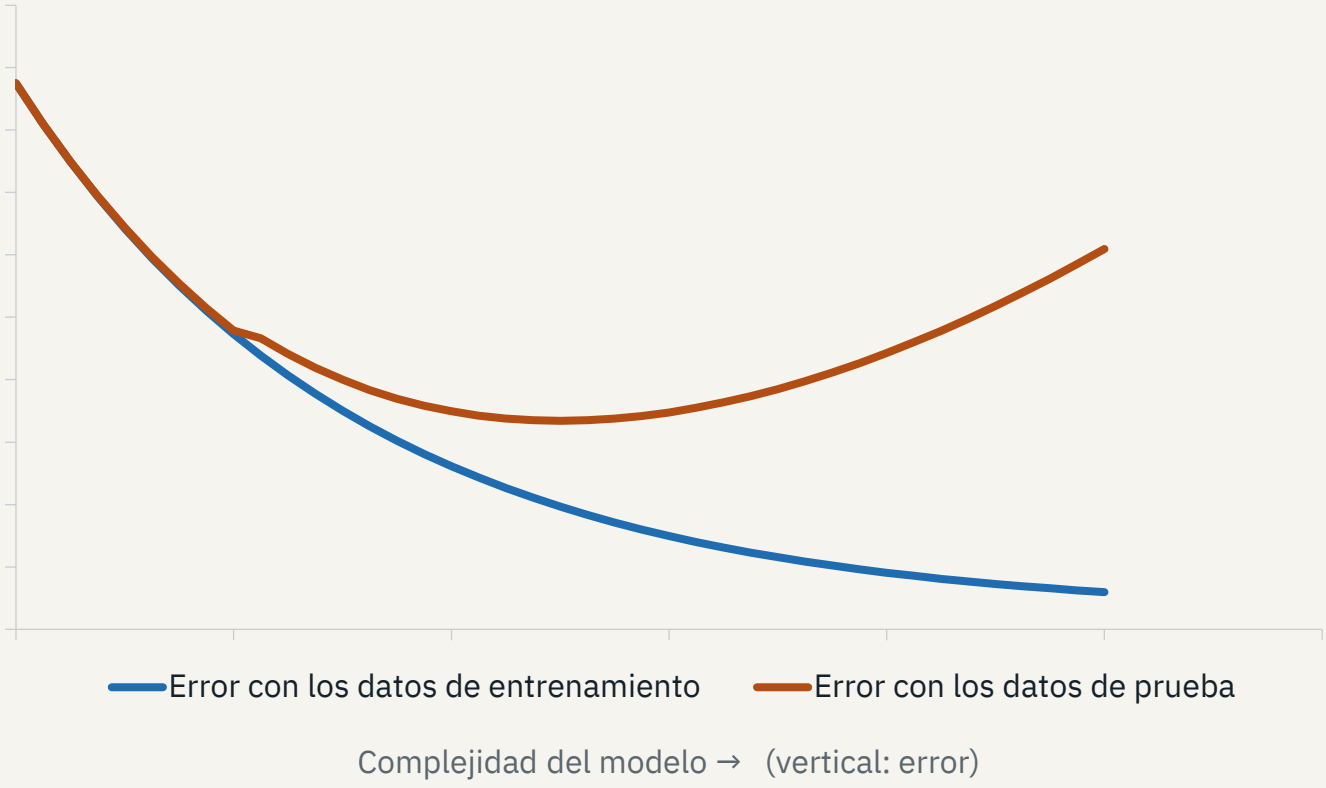
Se mantiene la proporción de cada clase en ambos lados.

LA REGLA DE ORO

Cada vez que miras la prueba para ajustar algo, **la contaminas**. Como un estudiante que ve el examen de antemano: saca 5,0 y no demuestra nada.

ML · MEMORIZAR O ENTENDER

# Sobreajuste y subajuste




SUBAJUSTE

Demasiado simple: no aprendió lo básico.

PUNTO JUSTO

Aprende lo general y falla poco con casos nuevos.

SOBREAJUSTE

Memorizó el entrenamiento, incluido su ruido: falla con casos nuevos.

SEÑAL DE ALARMA

Acierta mucho más en entrenamiento que en prueba.

# Los tipos de aprendizaje: depende de si hay respuestas

| TIPO | ¿HAY RESPUESTA? | QUÉ BUSCA | EN SEGURIDAD | PRÁCT. |
|---|---|---|---|---|
| **Supervisado** | Sí, en todos los casos | Predecir la respuesta de casos nuevos | ¿Es una amenaza real? | **1** |
| **No supervisado** | No | Descubrir estructura | Grupos de incidentes; lo raro | **3 y 4** |
| **Semisupervisado** | En unos pocos casos | Aprovechar los pocos casos con respuesta y los muchos sin ella | Pocos incidentes etiquetados por un analista | |
| **Autosupervisado** | Sale de los datos mismos | Aprender una representación general | Predecir la palabra siguiente: así se entrena un LLM | |
| **Por refuerzo** | Una recompensa, no una respuesta | Aprender probando, con premios y castigos | Defensa adaptativa y pruebas de penetración automáticas (experimental) | |

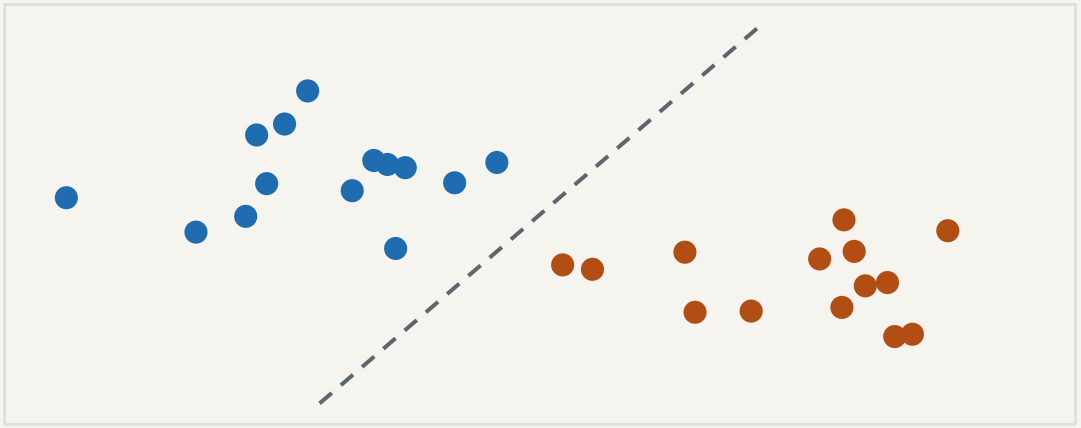
LA PREGUNTA GUÍA

¿Tengo en mis datos la respuesta correcta? Si sí, es supervisado. Si no, no supervisado.

ML · SUPERVISADO

# Aprendizaje supervisado: clasificar o estimar un número

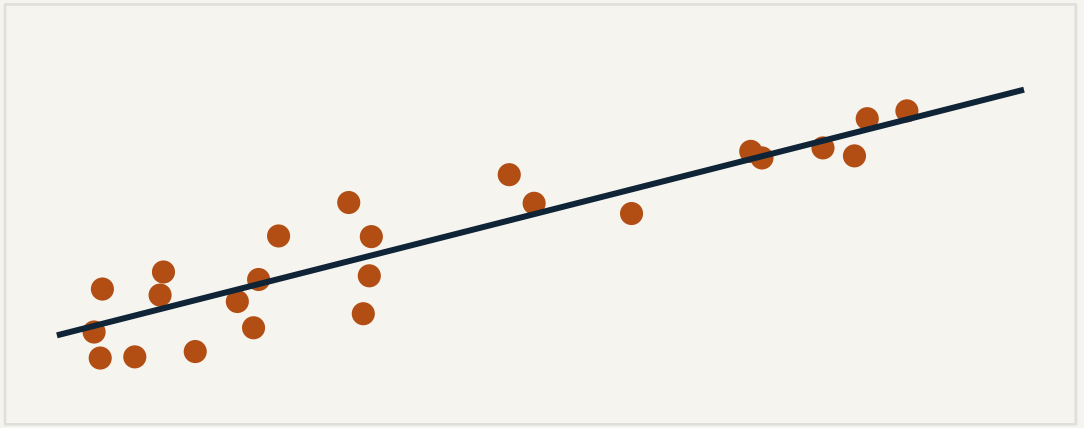
CLASIFICACIÓN



## La respuesta es una etiqueta

De una lista: *amenaza real / sin amenaza / actividad esperada*; *phishing / legítimo*.

REGRESIÓN



## La respuesta es un número

*¿Cuántos días tardará este incidente? ¿Qué probabilidad hay de que esta vulnerabilidad se explote?*

En la Práctica 1 clasificamos. La regresión usa las mismas ideas, pero la respuesta es una cantidad.

ML · NO SUPERVISADO

# Descubrir sin que nadie diga qué buscar

**1** **Segmentar (agrupar)** — PRÁCTICA 3
Juntar casos parecidos.

**2** **Detectar anomalías** — PRÁCTICA 4
Encontrar lo que no se parece a lo común.

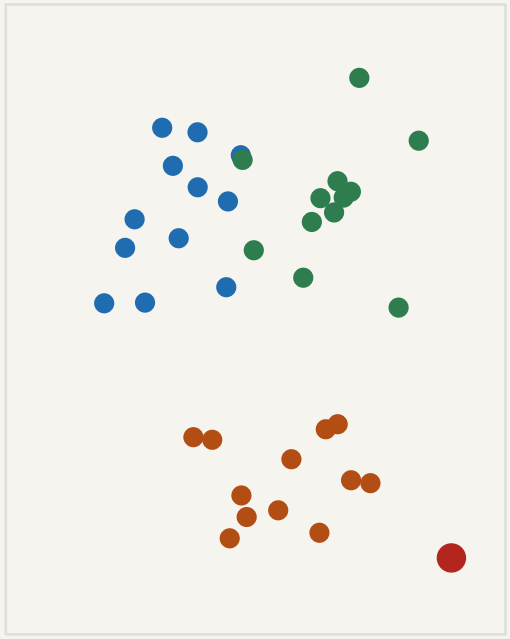
**3** **Reducir dimensiones**
Resumir muchas variables en pocas para poder verlas (PCA).

**4** **Reglas de asociación**
Descubrir qué aparece junto: «cuando ocurre A, suele ocurrir B».

SIN PREGUNTAS



CON GRUPOS Y UN PUNTO LEJANO



Sin respuestas correctas no hay «nota»: se evalúa con **utilidad, estabilidad y revisión humana** (diapositiva 44).

ML · LOS OTROS TRES

# Semisupervisado, autosupervisado y por refuerzo

SEMISUPERVISADO

## «Pocas etiquetas, muchos datos sin etiqueta»

Un analista etiquetó 500 incidentes; hay 500.000 sin etiquetar. El modelo aprovecha los dos grupos.

AUTOSUPERVISADO

## «El modelo se inventa su propio examen»

Esconde una parte de los datos y aprende a adivinarla. Así se entrenan los modelos de lenguaje: se tapa una palabra y se adivina.

POR REFUERZO

## «Aprender jugando»

El sistema prueba acciones y recibe premio o castigo. Sirvió para jugar ajedrez; en seguridad es **experimental** y delicado: una acción equivocada puede tumbar sistemas legítimos.

PARA RETENER

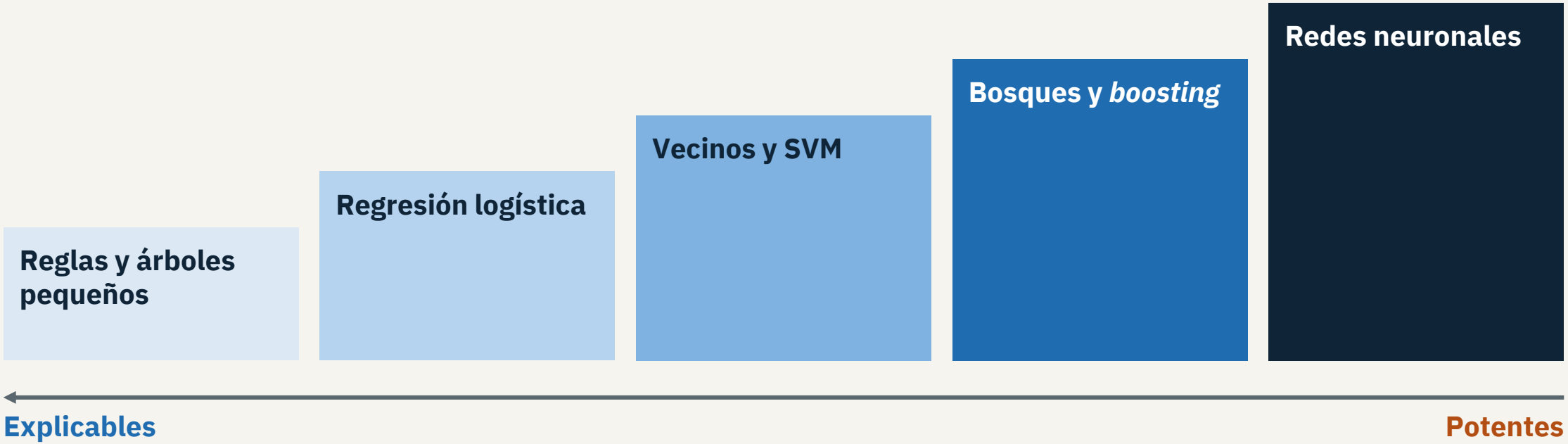
Verán estos nombres en toda la literatura. El autosupervisado es lo que hizo posibles los grandes modelos de lenguaje.

# Preparar los datos: donde se gana o se pierde casi todo

| PROBLEMA | QUÉ SE HACE O QUÉ PASA |
|---|---|
| **Datos que faltan** | Se rellenan, se eliminan o se marcan. |
| **Valores extremos** | ¿Error o caso importante? *(un incidente abierto 300 días)* |
| **Categorías → números** | «Táctica de ataque» se convierte en columnas de sí/no. |
| **Escalas distintas** | *8 días* frente a *3 cambios de estado*: se estandarizan. |
| **Distribuciones sesgadas** | El logaritmo acerca los valores grandes. |
| **Clases desbalanceadas** | Si solo el 8 % son amenazas reales, «nada es amenaza real» acierta 92 %. |
| **Fuga de información** | **Una variable que contiene la respuesta, o información del futuro.** |

Se dice que el 80 % del trabajo es preparar los datos. La más traicionera es la **fuga de información**: el modelo «acierta» sin aprender nada.

# Las familias de modelos: más potencia, menos explicación




NO HAY UN MODELO «MEJOR»

Existe el que **conviene** para la decisión. Casi siempre, a más precisión, **menos capacidad de explicar por qué**.

# Árboles de decisión: una cascada de preguntas




Árbol ilustrativo: las preguntas y los cortes no son los de la práctica.

VENTAJA

### Se puede leer entero

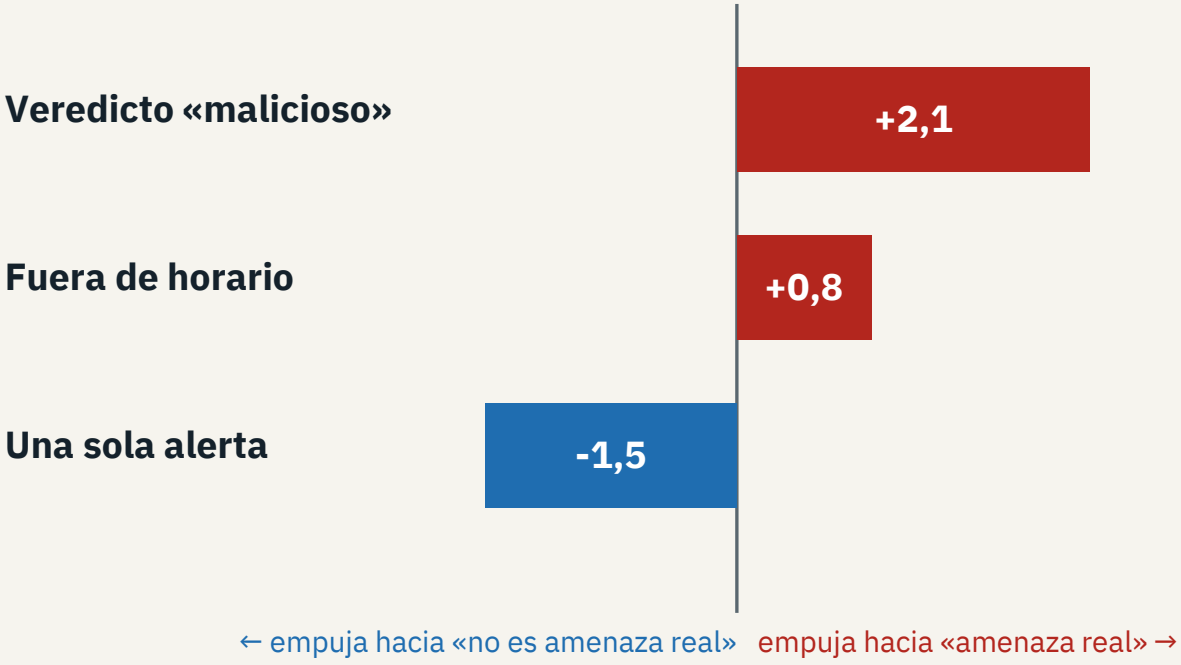
Se explica pregunta por pregunta, como el juego de las veinte preguntas.

LÍMITE

### Si crece mucho, memoriza

Sin límite de niveles aprende de memoria el entrenamiento.

# Regresión logística: un peso por variable




PROBABILIDAD

**0 a 1**

VENTAJA Y LÍMITE

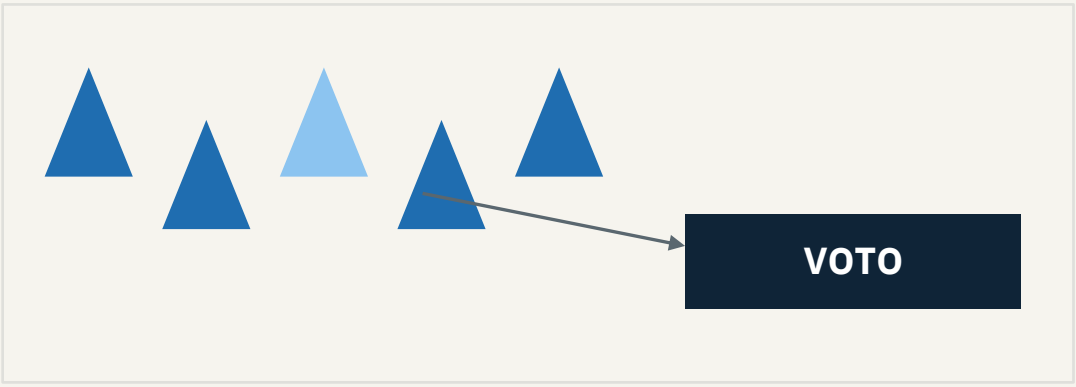
Cada variable tiene un **peso** que se lee.

Solo capta relaciones «en línea recta».

Pesos ilustrativos. Es un método de **clasificación**, no de regresión numérica.

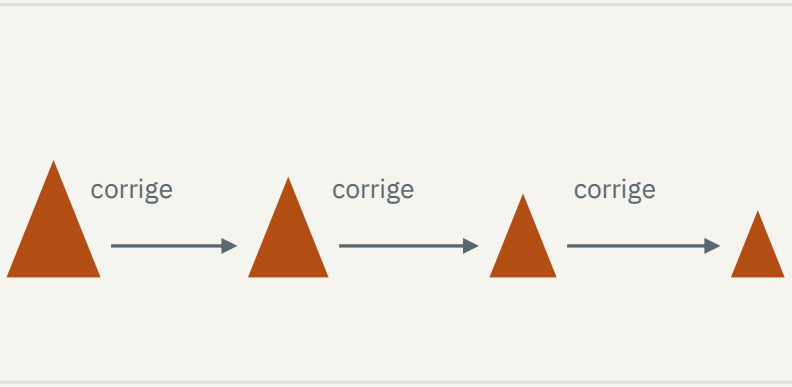
# Bosques aleatorios y gradient boosting: muchos árboles

## BOSQUE ALEATORIO




200 árboles, cada uno con una parte distinta de los datos, **votan**. Se equivocan de formas distintas y el voto compensa.

## GRADIENT BOOSTING



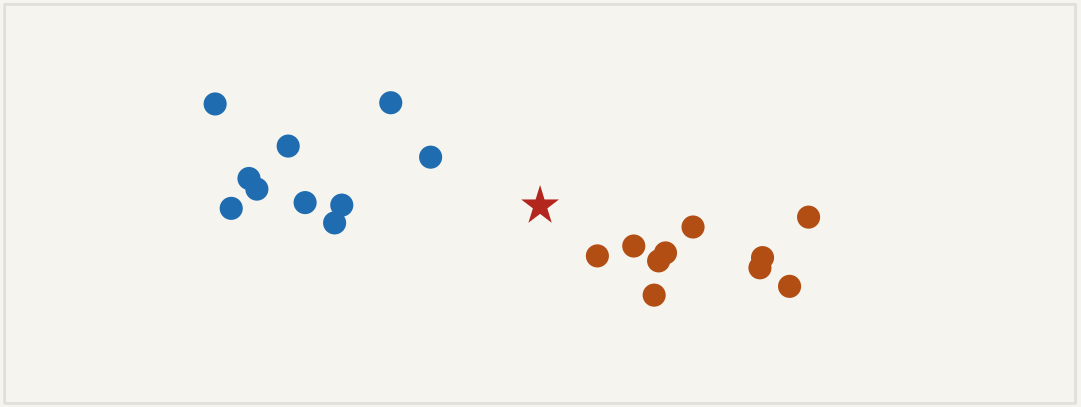

Un árbol pequeño, luego otro **que corrige los errores del anterior**, y así muchas veces.

HOY

Son lo que **más se usa con tablas de datos** (XGBoost, LightGBM, CatBoost). A cambio, ya no se puede leer el modelo entero.

# Vecinos más cercanos y SVM, en una diapositiva

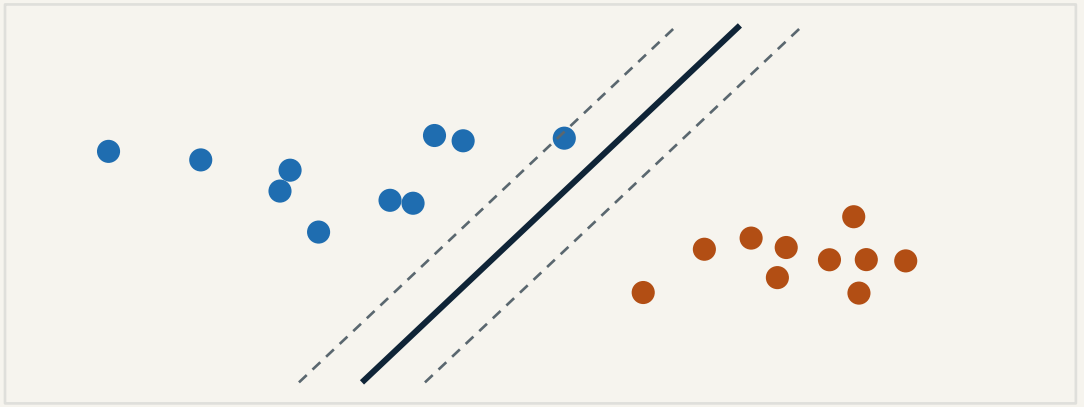
K VECINOS



## «Dime con quién andas»

Un caso nuevo se clasifica como la mayoría de sus vecinos más parecidos.

SVM · MÁQUINA DE VECTORES DE SOPORTE



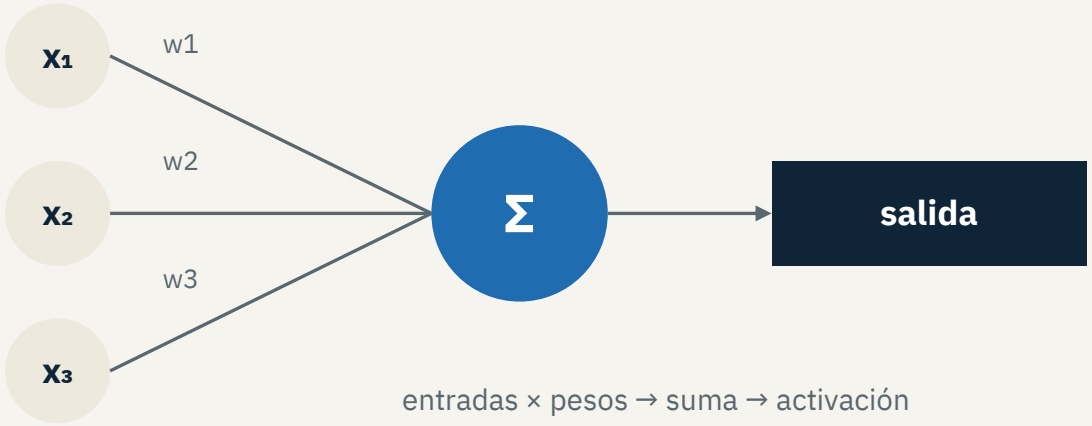
## Busca la frontera con mayor margen

Encuentra la frontera que mejor separa dos clases, dejando el mayor margen posible.

Son clásicos que verán nombrados. Con datos como los de hoy, los bosques y el *boosting* suelen ganarles: no los usaremos.

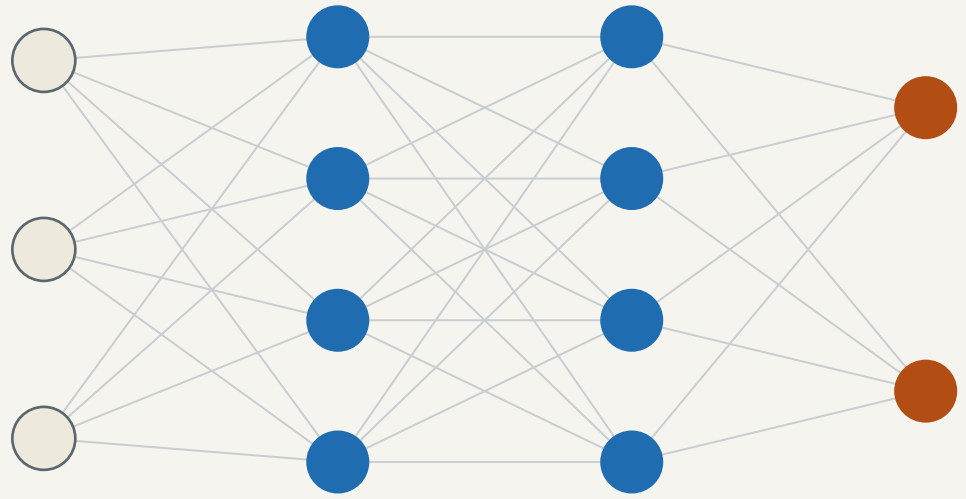
# La neurona y las capas

## UNA NEURONA




entradas × pesos → suma → activación

## UNA RED

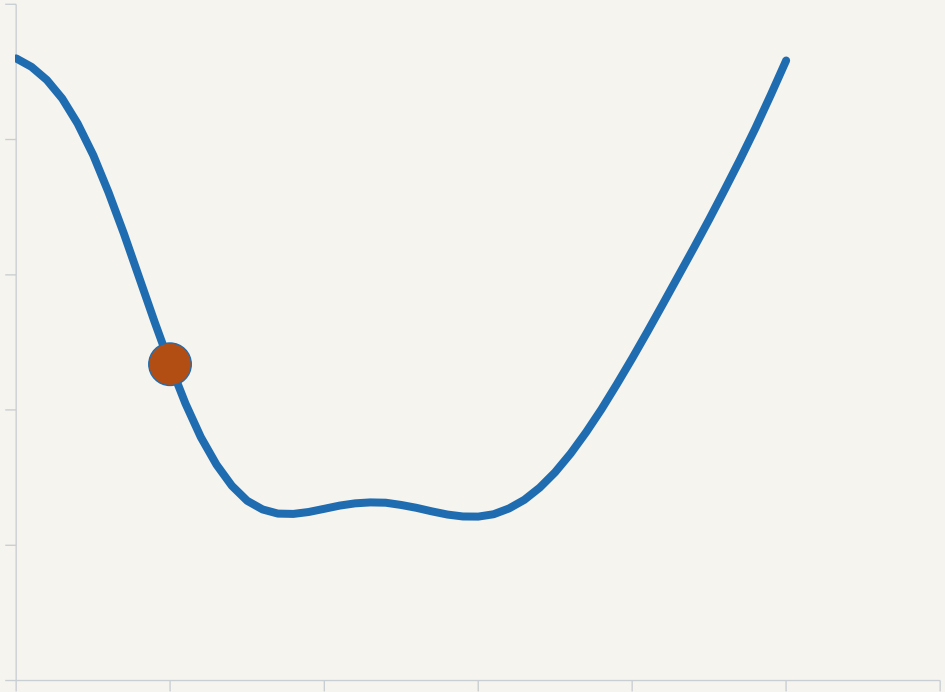



FRASE CLAVE

Una neurona artificial es una **regresión logística** pequeña. Una red es **muchas** conectadas en capas.

# Cómo aprende una red

| | |
|---|---|
| **Error (pérdida)** | Qué tan mal responde la red. |
| **Entrenar** | Ajustar los pesos para que el error baje (descenso del gradiente, con *retropropagación*). |
| **Época** | Una pasada completa por todos los datos de entrenamiento. |
| **Tasa de aprendizaje** | Qué tan grande es cada ajuste: muy alta, se pasa; muy baja, tarda. |
| **Parámetros** | Todos los pesos que la red ajusta: miles en una red pequeña; miles de millones en un modelo de lenguaje. |



El error baja ladera abajo, paso a paso.

# Aprendizaje profundo: tipos de redes y cuándo valen la pena

| RED | PARA QUÉ SIRVE | EN SEGURIDAD |
|---|---|---|
| **Perceptrón multicapa (MLP)** | Datos en tabla | Clasificar incidentes (Práctica 1) |
| **Convolucional (CNN)** | Imágenes | Analizar capturas; malware convertido en imagen |
| **Recurrente / LSTM** | Secuencias | Secuencias de eventos o de registros |
| **Autoencoder** | Comprimir y reconstruir | Detección de anomalías (Práctica 4) |
| **Transformer** | Texto y secuencias largas, con atención | Modelos de lenguaje; análisis de texto |

CUÁNDO SÍ

Muchos datos, y datos sin estructura: texto, imagen, audio.

CUÁNDO NO

Pocos datos, datos en tabla, y cuando hay que explicar la decisión.

# Del transformer a la IA generativa: la pieza siguiente

1
**Transformer**
2017

→

2
**Modelos de lenguaje**
Entrenados con texto masivo

→

3
**ChatGPT y otros asistentes**
2022 en adelante

Mecanismo: **predice la siguiente pieza del texto, una y otra vez.**

TRES USOS EN SEGURIDAD

**Resumir** una alerta compleja.

**Traducir** una pregunta a una consulta (SPL, KQL).

**Explicar** un script ofuscado.

TRES RIESGOS

**Alucinación**: inventa con seguridad.

**Inyección de instrucciones**: el contenido que analiza le da órdenes.

**Fuga de datos**: lo que le pegas sale de tu organización.

# ¿Qué modelo uso? Una guía práctica

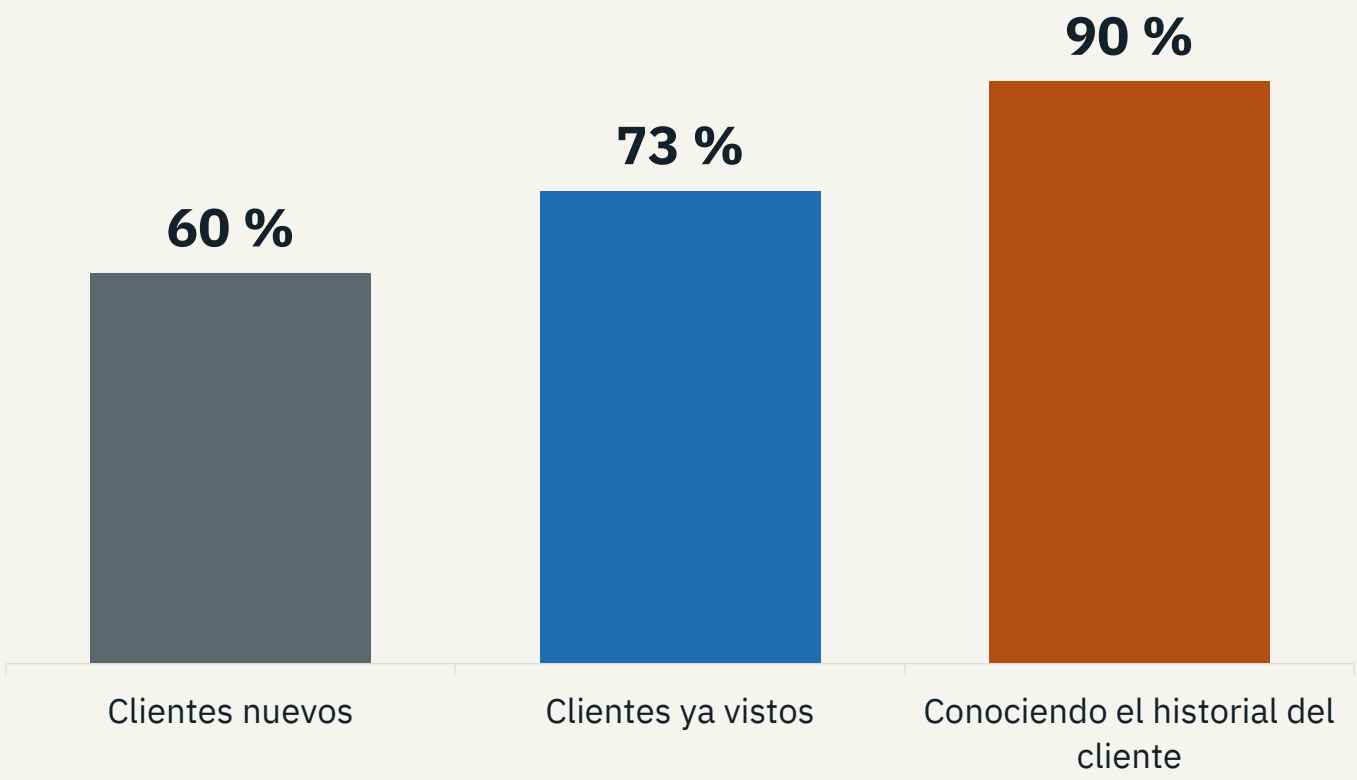
| SI… | EMPIEZA CON… |
|---|---|
| **Tengo una tabla de datos y poca explicación que dar** | *Gradient boosting* o bosque aleatorio |
| **Tengo que explicar cada decisión** | Árbol pequeño o regresión logística |
| **Tengo poco dato** | Modelos simples (no una red) |
| **Es texto, imagen o audio** | Aprendizaje profundo o un modelo de lenguaje |
| **No hay respuesta correcta en mis datos** | Segmentación o detección de anomalías |
| **Lo único que importa es acertar y puedo justificarlo con pruebas** | El que mejor puntúe en una **prueba honesta** |

REGLA DE ORO

**Empieza con lo simple.** Si un modelo complicado no supera con claridad a un árbol pequeño o a una regresión logística, no lo necesitas.

EVALUACIÓN · EL ADELANTO

# La cifra más alta casi siempre es la menos honesta




LA PREGUNTA

## ¿Cuál es la exactitud del modelo?

El **mismo modelo**, con los **mismos datos**.

Cambia **cómo lo mides**. Al final de la Práctica 1 sabrán por qué.

Referencia: la clase mayoritaria acierta 49,2 %.

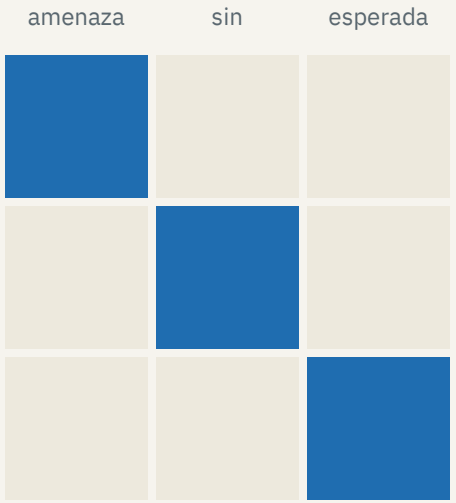
EVALUACIÓN · LA MATRIZ DE CONFUSIÓN

# Aciertos y errores, ordenados

| | Dijo «amenaza real» | Dijo otra etiqueta |
|---|---|---|
| **Era amenaza real** | ACIERTO **Verdadero positivo** | ERROR **Falso negativo** *el incendio sin alarma* |
| **Era otra etiqueta** | ERROR **Falso positivo** *la alarma falsa* | ACIERTO **Verdadero negativo** |

Clase «positiva»: amenaza real. Falso positivo y falso negativo son errores del modelo, no etiquetas.

CON TRES ETIQUETAS

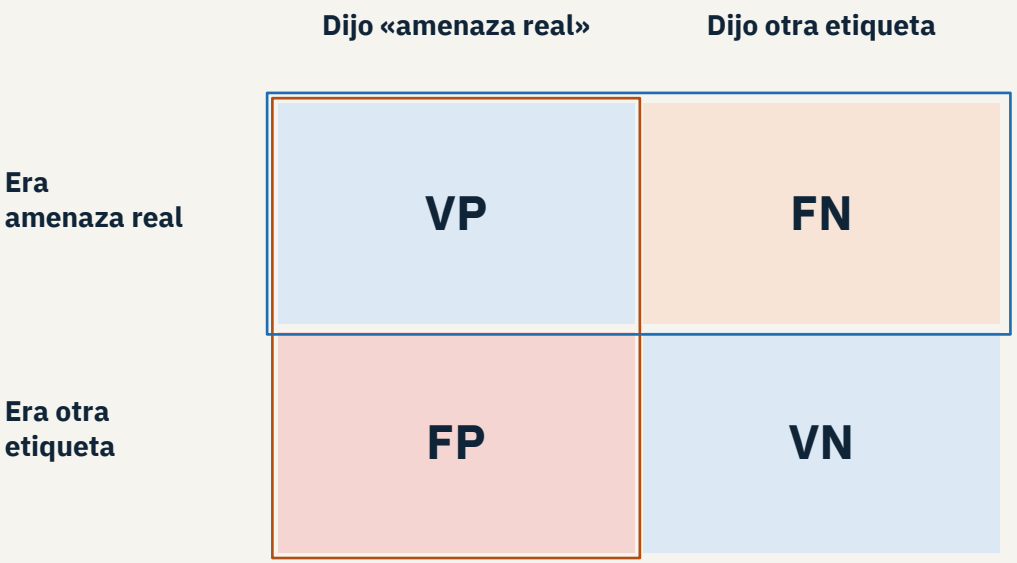



3 × 3: la diagonal (azul) son los aciertos.

LOS ERRORES NO CUESTAN LO MISMO

La alarma falsa nos hace perder tiempo; el incendio sin alarma nos lo puede quemar todo.

# Exactitud, precisión, recall y F1, en palabras




Marco azul: recall (fila) · marco naranja: precisión (columna)

EXACTITUD

De todos los casos, ¿cuántos acertó?

aciertos ÷ total

PRECISIÓN

De los que **marcó** como amenaza real, ¿cuántos lo eran?

¿Puedo creerle cuando alarma?

RECALL (EXHAUSTIVIDAD)

De las amenazas reales que **había**, ¿cuántos encontró?

¿Qué se me escapa?

F1

Una sola cifra que mezcla precisión y recall.

Baja si cualquiera de las dos es baja.

Se compran una con la otra: una alarma muy sensible tiene alto recall y baja precisión.

EVALUACIÓN · LA LÍNEA BASE

# La exactitud engaña cuando hay pocas amenazas reales

Si solo el **8 %** de los incidentes son amenazas reales, un «modelo» que responda **siempre «no es amenaza real»**…




…y no detecta **ninguna** amenaza real.

LÍNEA BASE

**Lo que acertaría un modelo que no mira los datos**

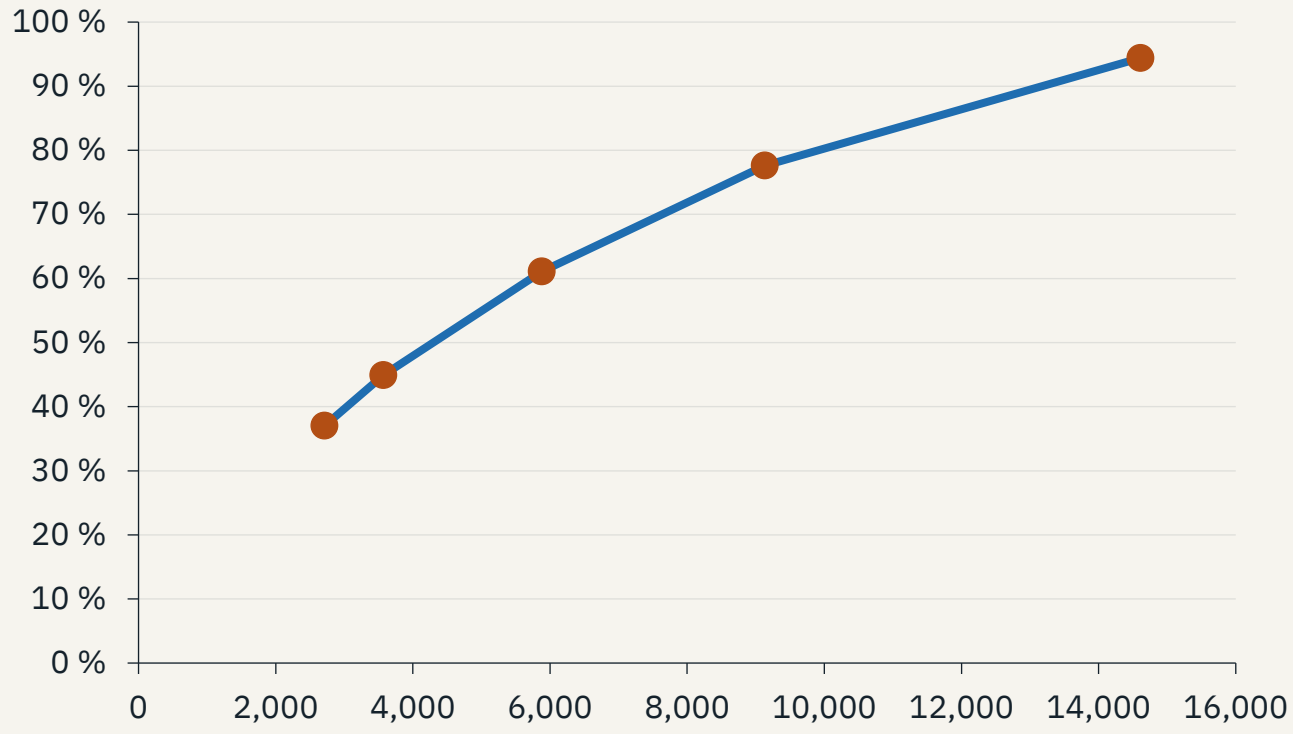
Cualquier modelo debe superarla. En la Práctica 1 es 49,2 %.

DOS RECOMENDACIONES

Mirar el **recall de la clase que importa**.

Comparar siempre con la línea base.

# Cuántos revisar es una decisión de negocio




Horizontal: incidentes a revisar (de 24.000 en la prueba) · vertical: % de las amenazas reales encontradas

| UMBRAL | A REVISAR | AMENAZAS |
|---|---|---|
| **Alto (0,5)** | 2.712 | **37 %** |
| **Bajo (0,1)** | 14.611 | **94 %** |

El modelo da una **probabilidad**; el corte lo escogemos nosotros.

Bajarlo encuentra más amenazas reales, pero obliga a revisar más y causa **fatiga de alertas**.

ESA DECISIÓN ES DE NEGOCIO

No del modelo.

CLASES DESBALANCEADAS · ENTRENAR

# Enseñarle al modelo a mirar lo poco frecuente

Si las amenazas reales son la minoría, el modelo aprende a **ignorarlas**. Cuatro maneras de corregirlo **al entrenar**:

| MÉTODO | QUÉ HACE | A FAVOR | EN CONTRA |
|---|---|---|---|
| **Pesos de clase** | Cada error en la clase rara **cuesta más** al aprender. | Usa todos los datos; es una línea de código. | Cambia la escala de las probabilidades. |
| **Sobremuestreo** | Copia casos de la clase rara, o **inventa** casos nuevos entre vecinos (SMOTE). | No se pierde ningún dato. | Las copias se memorizan; los inventados pueden ser irreales. |
| **Submuestreo** | **Quita** casos de la clase común hasta equilibrar. | Rápido y liviano. | Tira información; el modelo se vuelve inestable. |
| **Datos sintéticos** | Un modelo generativo **crea** casos raros nuevos. | Sirve con datos complejos. | Difícil de validar; puede inventar patrones. |

LO QUE TIENEN EN COMÚN

Los cuatro cambian **cuánto pesa cada clase** al aprender. Ayudan a encontrar la clase rara, pero **distorsionan las probabilidades**.

# Evaluar con pocas amenazas reales: la prueba no se toca

1 **Partir** estratificado: la misma proporción en ambos lados

2 **Rebalancear** solo el entrenamiento

3 **Entrenar** con los datos ya rebalanceados

4 **Probar** en la prueba intacta, con la proporción real

5 **Medir** por clase y, además, la calibración

QUÉ MEDIR

## La clase rara, no el promedio

**Recall y precisión** de la clase que importa.

**F1** o **G-mean** en lugar de la exactitud.

**Curva precisión–recall**: su línea base es la proporción de la clase rara.

LAS TRAMPAS

## Dos formas de engañarse

**Rebalancear antes de partir**: las copias caen a ambos lados y la cifra se infla.

**Probar con datos rebalanceados**: mide un mundo que no existe.

Con pocos casos raros, **repetir con otras particiones**: una sola cifra es ruidosa.

LA REGLA

Se rebalancea el entrenamiento; la prueba se queda **como es el mundo**.

# Rebalancear estropea las probabilidades: hay que recalcularlas

EL PROBLEMA

Al rebalancear, el modelo cree que las amenazas reales son **la mitad** de los incidentes, no el 21 %. Su **orden** sirve; su **probabilidad**, no.

LA CORRECCIÓN

Se deshace el efecto del rebalanceo: la probabilidad baja según cuánto se rebalanceó.

$$p_{\text{corregida}} = \frac{k \cdot p}{1 + p \cdot (k - 1)}$$

k = % de amenazas ÷ % del resto = 0,26

EN LOS DATOS DE LA PRÁCTICA 1 · «AMENAZA REAL» CONTRA EL RESTO

| REGRESIÓN LOGÍSTICA | RECALL | PRECISIÓN | PROB. MEDIA |
|---|---|---|---|
| **Sin balancear · umbral 0,5** | 3,7 % | 57,8 % | **20,7 %** |
| **Con pesos · umbral 0,5** | 68,7 % | 33,1 % | **45,7 %** |
| **Con pesos · probabilidad corregida · umbral 20,7 %** | 68,7 % | 33,1 % | **20,6 %** |

La proporción real de amenazas en la prueba es **20,7 %**. Con pesos, entre los incidentes con probabilidad de **60 % o más**, solo el **37 %** lo eran.

Corregir no cambia ninguna etiqueta: el recall y la precisión quedan **idénticos**.

UNA ALTERNATIVA QUE NO TOCA LOS DATOS

En este ejemplo, mover el umbral a 20,7 % en el modelo sin balancear da casi lo mismo (recall 69,3 %, precisión 33,3 %) y deja las probabilidades honestas.

EVALUACIÓN · CÓMO SE PARTEN LOS DATOS

# Al azar, por tiempo o por grupo

AL AZAR



**¿Acierta con casos parecidos a los que vio?**
Es la más cómoda y la más optimista.

POR TIEMPO




**¿Acierta mañana?**
Entrenar con el pasado, probar con el futuro.

POR GRUPO



**¿Acierta con un cliente nuevo?**
Todos los casos de un cliente van a un solo lado.

Azul: entrenamiento · naranja: prueba

FUGA DE INFORMACIÓN

Que el entrenamiento incluya pistas de la prueba: casos casi idénticos, la misma organización, el mismo periodo.

EVALUACIÓN · SIN RESPUESTAS CORRECTAS

# Evaluar cuando no hay respuestas correctas

SEGMENTACIÓN · NO HAY ETIQUETA

## ¿El agrupamiento sirve?

¿Los grupos se **describen** bien?

¿Son **estables** si repito el proceso?

¿**Sirven** para decidir algo distinto en cada uno?

Apoyo: la **silueta** (qué tan separados están).

ANOMALÍAS

## ¿El detector encuentra lo raro?

**Inyectar** anomalías conocidas y ver cuántas atrapa.

Un **indicador indirecto**: por ejemplo, el incumplimiento del plazo.

**Revisión humana** de lo que marca.

CADA EVALUACIÓN MIDE ALGO DISTINTO

Un método no supervisado siempre entrega *algo*: hay que ver si lo que entrega sirve y se sostiene.

EVALUACIÓN · EXPLICABILIDAD

# Explicabilidad y confianza: ¿puedo justificar la decisión?

MODELOS LEGIBLES

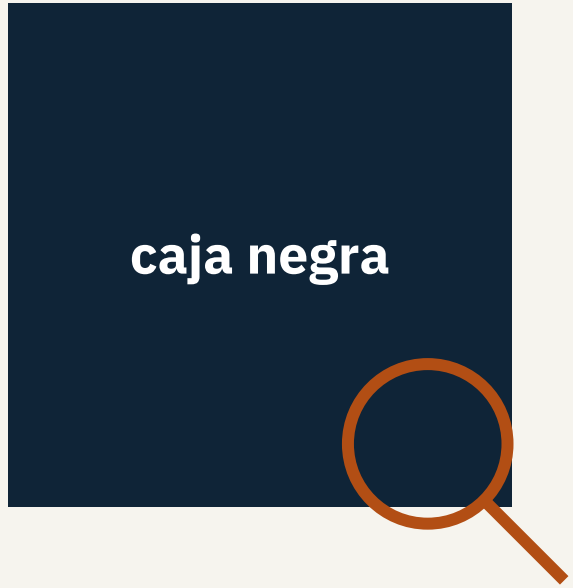
**Árbol pequeño, regresión logística**

El modelo **es** la explicación.

EXPLICACIONES APROXIMADAS

**Importancia de variables, SHAP**

Una explicación hecha **desde fuera** de una caja negra: sirve para sospechar, no para dar certeza.




LA PREGUNTA DE FONDO

¿Qué pasa si el modelo se equivoca con una persona, una cuenta o un cliente?

PRÁCTICA 1 · 55 MINUTOS

# Práctica 1: clasificar incidentes

LA PREGUNTA

## ¿Amenaza real, sin amenaza o actividad esperada?

LOS DATOS

**Incidentes reales de Microsoft (GUIDE)**: 80.000 incidentes de 3.013 organizaciones. Etiquetas: *amenaza real*, *sin amenaza*, *actividad esperada*. Línea base: 49,2 %.

Practica_1_Clasificacion.ipynb
github.com/lsandinop/analitica-procesos-ciberseguridad

1. **Mirar los datos**
2. **Qué se relaciona con la etiqueta**
3. **Seis modelos**
4. **Cómo medir**
5. **Umbral y costo**

QUÉ SE ENTREGA AL FINAL

Una frase: «¿por qué el mismo modelo acierta entre 60 % y 90 %?». La sección 5 (la medición honesta) es la parte importante.

PRÁCTICA 1 · DEMO CON IA GENERATIVA

# La IA como ayudante de analítica descriptiva

**1**
**Adjuntar los datos**
guide_incidentes.csv · 80.000 incidentes

**2**
**Pedir el descriptivo**
de toda la base, sin modelo

**3**
**Contrastar con grado**
dos métodos de impacto, comparados

**4**
**Exigir el código**
y revisar antes de creer

## EL PROMPT (RESUMEN · EL COMPLETO, EN LAS NOTAS)

**Eres analista de un SOC. Adjunto 80.000 incidentes; el objetivo es grado.**

1 Calidad y estructura de la base.
2 Descriptivo: media, mediana, p90, máximo, % de ceros.
3 Contraste de cada variable con grado.
4 Impacto con DOS métodos, y compáralos.
5 organizacion y detector_principal: aparte.
6 Ranking de 10 variables, en lenguaje de analista.
7 Límites: asociación no es causalidad.

**Todo número debe salir de código ejecutado.**

## EN EL REPOSITORIO

datos/ · los datos

salida_demo/ · el resultado

github.com/lsandinop/analitica-procesos-ciberseguridad

## QUÉ SE BUSCA QUE NOTEN

Los dos métodos no coinciden · las variables con muchos niveles engañan · una IA puede inventar cifras: por eso se le pide el código.

SESIÓN 2 · REPASO

# Lo que vimos y lo que sigue

SESIÓN 1 · CLASIFICAR

- Variables y etiqueta
- Modelos: árboles, bosques, redes
- Evaluación y línea base
- Umbral y costo
- Cómo se parten los datos

HOY

PRÁCTICA 2
**Procesos**

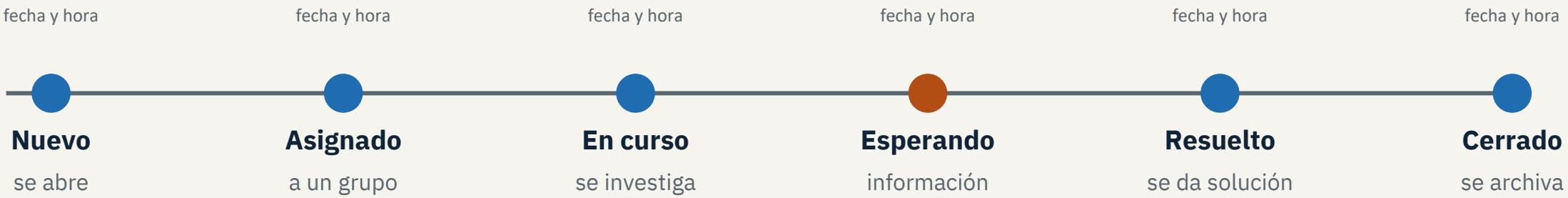
PRÁCTICA 3
**Grupos**

PRÁCTICA 4
**Anomalías**

PREGUNTA DE REPASO · 5 MINUTOS

¿Qué les sorprendió de la Práctica 1?

# Todo proceso deja una huella en los sistemas




PREGUNTA 1

¿Cómo se hace **de verdad**?

PREGUNTA 2

¿Se sigue el procedimiento?

PREGUNTA 3

¿Dónde se pierde el tiempo?

EL PROCEDIMIENTO ESCRITO ES CÓMO CREEMOS QUE SE HACE

Los registros del sistema son **cómo se hace**. La diferencia suele ser lo más interesante y, en seguridad, lo más riesgoso.

MINERÍA DE PROCESOS · DOS MINERÍAS

# Minería de datos y minería de procesos: preguntas distintas

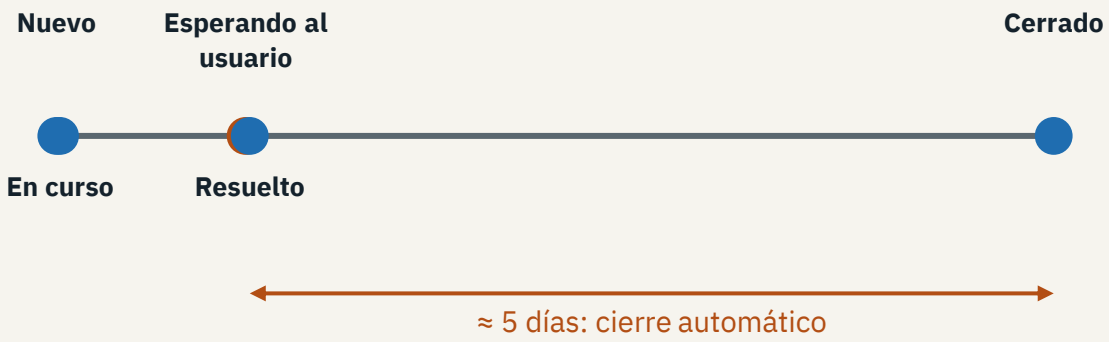
| | MINERÍA DE DATOS / ML | MINERÍA DE PROCESOS |
|---|---|---|
| **Pregunta** | ¿Qué **características** se relacionan con un resultado? | ¿En qué **orden** pasan las cosas y cuánto **tardan**? |
| **Ve** | Una tabla: una fila por caso | Una **secuencia de eventos** con fecha |
| **Ejemplo** | ¿Qué hace que un incidente sea una amenaza real? | ¿Cómo se atiende un incidente y dónde espera? |

SE PUEDEN COMBINAR

Del proceso salen variables (cuántas esperas, cuántas reasignaciones) que alimentan un modelo. La prueba: si tu pregunta depende del **orden** y del **tiempo**, necesitas minería de procesos.

# Caso, actividad y fecha

| CASO | ACTIVIDAD | FECHA Y HORA |
|---|---|---|
| **INC0000047** | Nuevo | 29/02 04:57 |
| **INC0000047** | En curso | 29/02 05:30 |
| **INC0000047** | Esperando al usuario | 01/03 09:14 |
| **INC0000047** | Resuelto | 01/03 09:52 |
| **INC0000047** | Cerrado | 06/03 10:00 |




Ejemplo real del registro de ServiceNow de la Práctica 2.

EL «ALFABETO» DE LA MINERÍA DE PROCESOS

Con solo tres datos —**caso**, **actividad**, **fecha**— se puede reconstruir un proceso.

# Tres cosas se pueden hacer con un registro de eventos

**1**

## Descubrir

A partir de los datos, dibujar el proceso **real**, sin partir de nada escrito.

**2**

## Comprobar conformidad

Comparar el proceso real con el **esperado** (el procedimiento o el *playbook*) y señalar desviaciones.

**3**

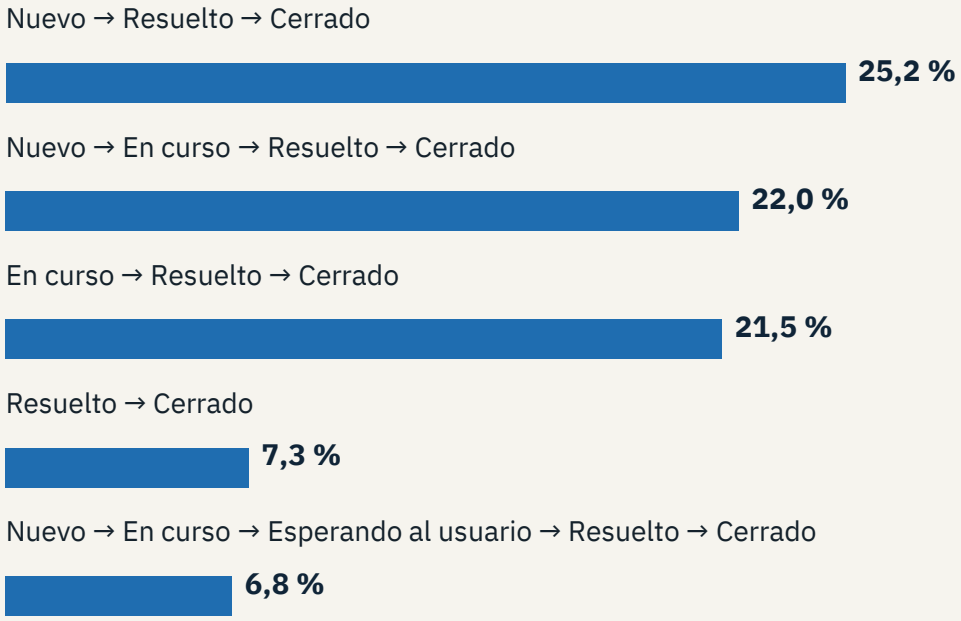
## Mejorar

Usar las fechas para encontrar **cuellos de botella** y tiempos de espera.

Lo nombra el *Process Mining Manifesto* (IEEE): descubrimiento, conformidad y mejora. Las tres, en la práctica.

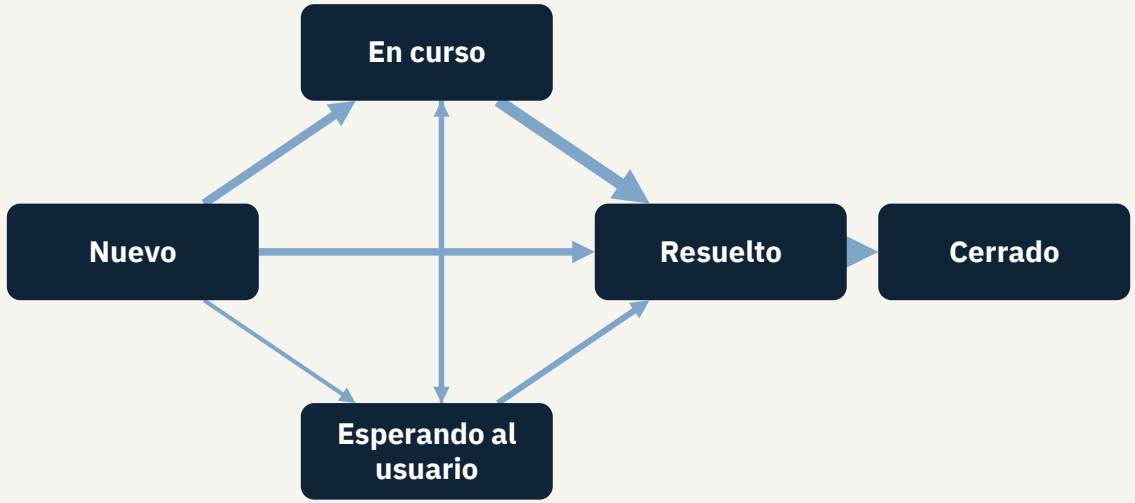
# Variantes y mapas: pocos caminos concentran casi todo

## LAS VARIANTES MÁS FRECUENTES




Las otras 183 variantes suman 17,2 %.

## MAPA SIMPLIFICADO · GROSOR = CANTIDAD




**188** variantes distintas, pero **5 cubren el 80 %.** Simplificar un mapa lo aclara, pero oculta las excepciones.

# Conformidad: ¿se siguió el procedimiento?

EN LA PRÁCTICA

**31 %**

de los incidentes sigue el procedimiento. El desvío más común: resolver **sin pasar por «En curso»**.

CUATRO MEDIDAS DE UN MODELO DE PROCESO

**Fitness**
¿Reproduce lo que pasó?

**Precisión**
¿Permite solo lo que ocurre?

**Generalización**
¿Aguanta casos nuevos?

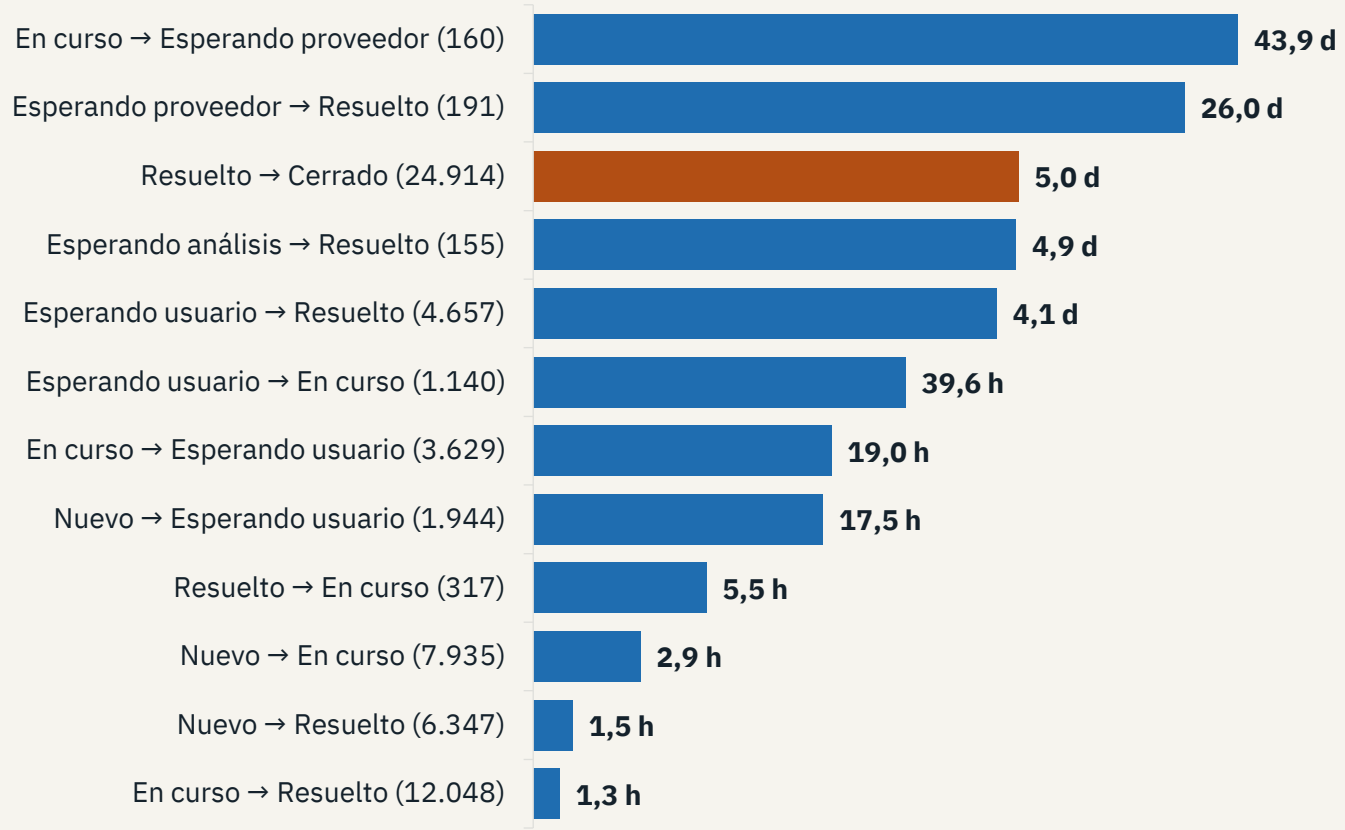
**Simplicidad**
¿Es fácil de leer?

FITNESS Y PRECISIÓN SE CONTRAPONEN

Un modelo que permite todo reproduce todo, pero no dice nada. Y desviarse no es equivocarse: la conformidad **detecta** la diferencia; **juzgarla** requiere conocer el negocio.

MINERÍA DE PROCESOS · RENDIMIENTO

# Dónde se pierde el tiempo (y cuidado con las esperas fijas)




Mediana hasta el siguiente estado (escala logarítmica) · entre paréntesis, incidentes · traspasos con 150 casos o más

RESUELTO → CERRADO

Unos **5 días** en casi todos: no es trabajo, es un **cierre automático**.

EL PROVEEDOR

Esperas raras (menos de 200 casos) pero de **semanas**.

ESPERAR AL USUARIO

Incumplen el plazo **65 a 75 %**, frente a 16 a 22 % de los que no esperan.

*La espera no prueba causa: pueden ser incidentes más difíciles.*

MINERÍA DE PROCESOS · HACIA EL ML

# Del proceso al aprendizaje automático: variables y predicción

1
**Registro de eventos**

→

2
**Resumen por caso**
cuántos cambios, esperas, días

→

3
**Variables**

→

4
**Modelo**

EL SIGUIENTE PASO

¿Qué estado viene?

EL RESULTADO

¿Cumplirá el plazo?

EL TIEMPO RESTANTE

¿Cuánto falta para resolverlo?

MONITOREO PREDICTIVO DE PROCESOS

En las prácticas 3 y 4 convertimos la historia de cada incidente en ocho números y se los damos a un modelo.

# Herramientas y límites

## HERRAMIENTAS

**PM4Py**
Librería de Python; la que usamos (licencia AGPL).

**ProM**
Académica.

**Disco y Celonis**
Comerciales.

## LÍMITES

- Hace falta un registro **limpio**: relojes, duplicados, identificador de caso correcto.
- **Un incidente = un caso** es una decisión de modelado.
- Los registros contienen **datos de personas**: aplica protección de datos.

80 % DEL TRABAJO

Construir el registro de eventos: decidir qué es un caso, qué es una actividad y limpiar los tiempos.

PRÁCTICA 2 · 32 MINUTOS

# Práctica 2: minería de procesos

LA PREGUNTA

## ¿Cómo se atiende realmente un incidente?

LOS DATOS

**Registro de una mesa de servicio (ServiceNow)**: 24.916 incidentes, 141.697 eventos.

**El dato es de TI, no de seguridad: el proceso de gestionar un incidente es el mismo.**

Practica_2_Mineria_de_procesos.ipynb
github.com/lsandinop/analitica-procesos-ciberseguridad

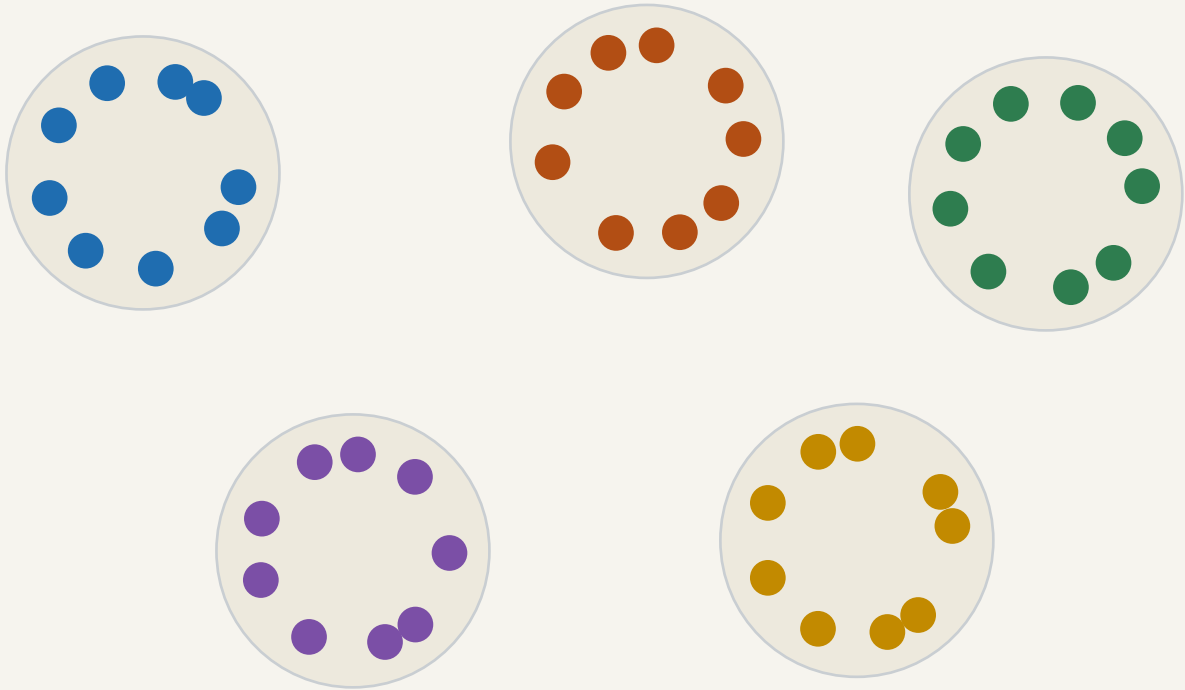
1 **Eventos** → 2 **Variantes** → 3 **Mapa** → 4 **Tiempos** → 5 **Conformidad (PM4Py)** → 6 **SLA**

QUÉ PEDIR AL GRUPO

Que miren primero el mapa **completo** y luego el simplificado, y que discutan qué se pierde al simplificar.

SEGMENTACIÓN · LA IDEA

# Segmentar es organizar mesas sin saber quién es quién



**Segmentar** = agrupar casos **parecidos entre sí** y **distintos de los de otros grupos**, sin que nadie diga cuáles son los grupos.

PARA QUÉ SIRVE EN SEGURIDAD

- Asignar equipos.
- Fijar plazos distintos.
- Auditar los casos raros.
- Definir **qué es «normal» para cada grupo**.

200 personas, 5 mesas, sin saber nada de ellas: **no hay respuesta correcta**; importa si los grupos sirven.

SEGMENTACIÓN · K-MEANS

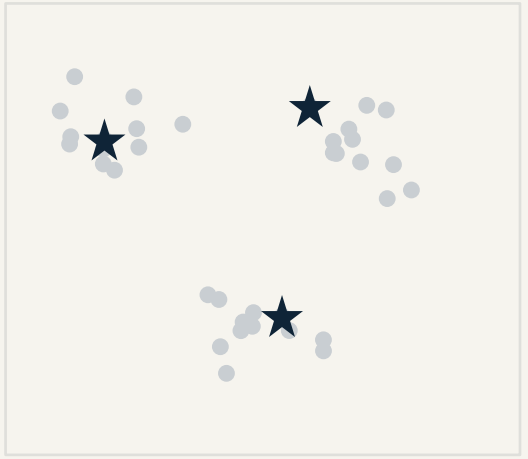
# K-means: cuatro pasos



**1**

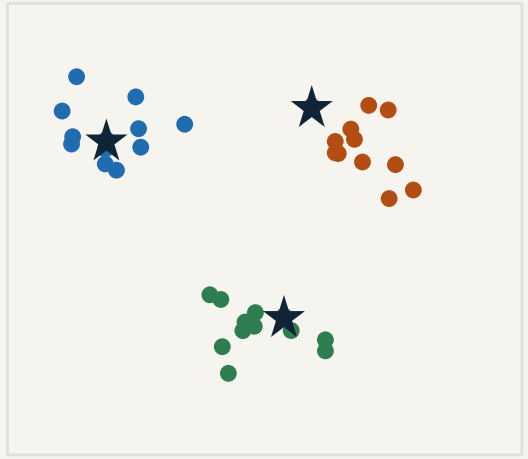
**Decir cuántos grupos (k)**

k = 3



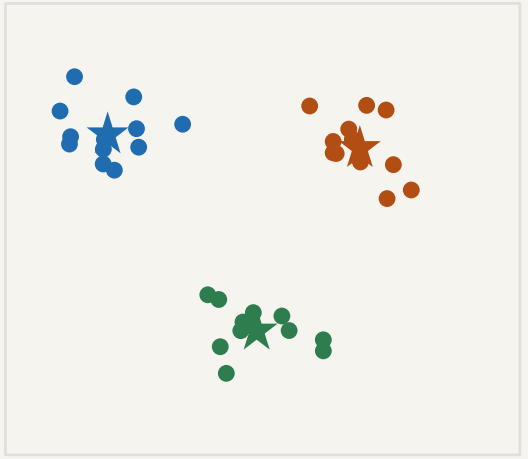
**2**

**Poner k «centros» al azar**



**3**

**Asignar cada caso al centro más cercano**



**4**

**Mover cada centro al promedio de su grupo**

y repetir 3 y 4

OTROS MÉTODOS

**Jerárquico**: une casos paso a paso. **DBSCAN**: grupos por densidad; separa el ruido. K-means: rápido y simple, pero hay que decirle cuántos grupos y le afectan los extremos.

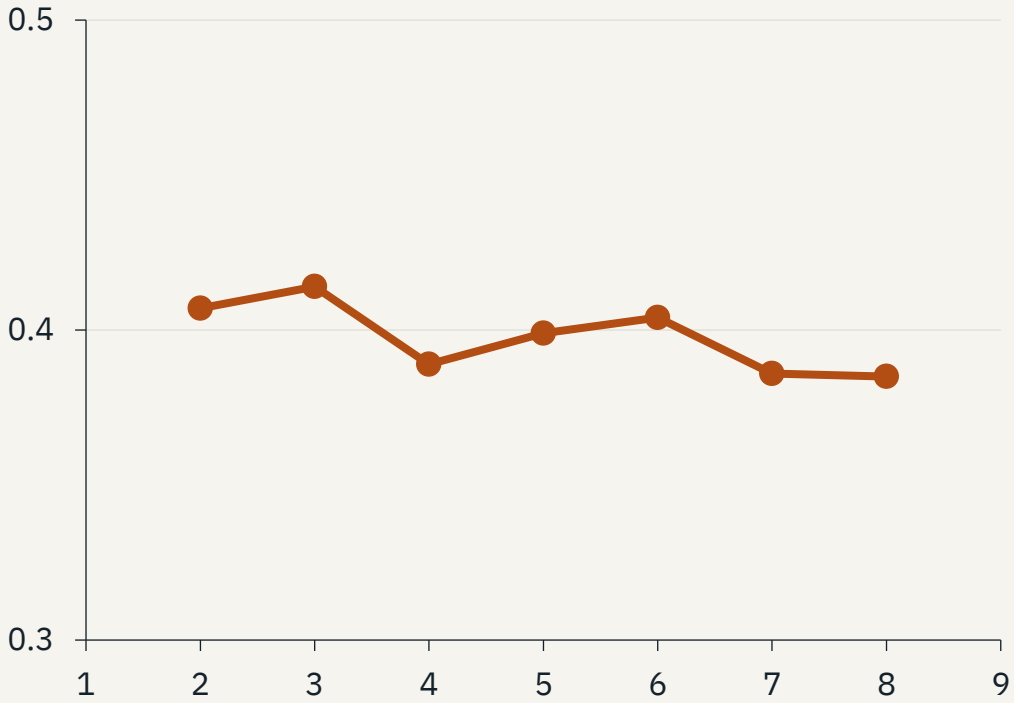
# Preparar y elegir cuántos grupos: la métrica no decide

PREPARAR

Pasar las variables a una **escala común** (estandarizar) y **domar los extremos** (logaritmo); si no, la variable con números grandes domina.

ELEGIR K

El **codo** (la inercia siempre baja: ¿dónde deja de bajar mucho?) y la **silueta** (qué tan separados están los grupos, de −1 a 1).



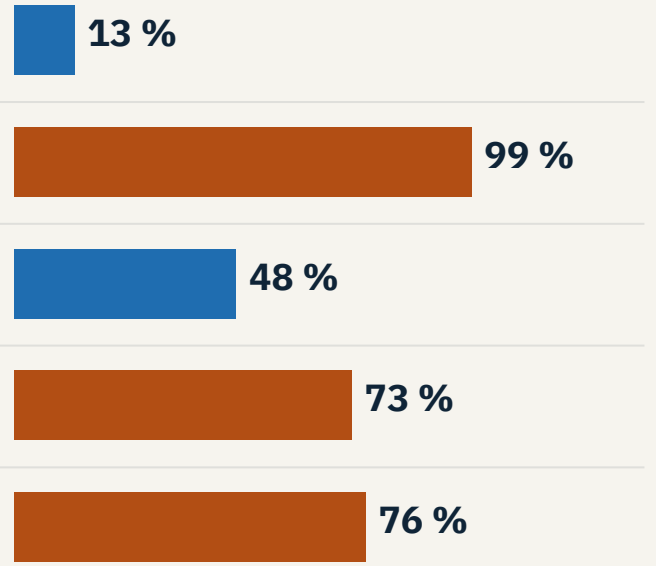

Silueta según el número de grupos (k): casi plana, entre 0,39 y 0,41

Si la métrica no decide, decide la **utilidad**: con 5 grupos aparece uno de prioridad alta que casi siempre incumple; con 4, se esconde.

SEGMENTACIÓN · PERFILES

# Un buen grupo se describe, se nombra y sirve

| GRUPO | INCIDENTES | INCUMPLEN EL SLA |
|---|---|---|
| **Rutina rápida** | 11.376 | **13 %** |
| **Prioridad alta** | 641 | **99 %** |
| **Cambian de manos** | 5.801 | **48 %** |
| **Con esperas** | 5.268 | **73 %** |
| **Reabiertos y complejos** | 274 | **76 %** |



SIN USAR EL SLA

No lo usamos para formar los grupos; sin embargo cambia de **13 % a 99 %** entre ellos: capturan algo real.

ESTABILIDAD

Con otros sorteos casi lo mismo (ARI 0,91 a 0,98); con otro método, el acuerdo es menor (0,63).

Se **describe**, es **estable** y **sirve** para hacer algo distinto con cada grupo.

PRÁCTICA 3 · 25 MINUTOS

# Práctica 3: segmentación

LA PREGUNTA

## ¿Qué tipos de incidentes hay?

LOS DATOS

El **mismo registro de la Práctica 2**, resumido a **una fila por incidente** (8 variables).
23.360 incidentes con datos completos.

Practica_3_Segmentacion.ipynb
github.com/lsandinop/analitica-procesos-ciberseguridad

1 **Resumir eventos** → 2 **Preparar** → 3 **¿Cuántos grupos?** → 4 **Ver** → 5 **Describir** → 6 **Confiabilidad**

QUÉ PEDIR AL GRUPO

Antes de ver los nombres, que cada persona **nombre los grupos** leyendo la tabla de perfiles. Casi siempre salen nombres distintos: esa es la lección.

# Una anomalía es lo que no se parece a lo habitual

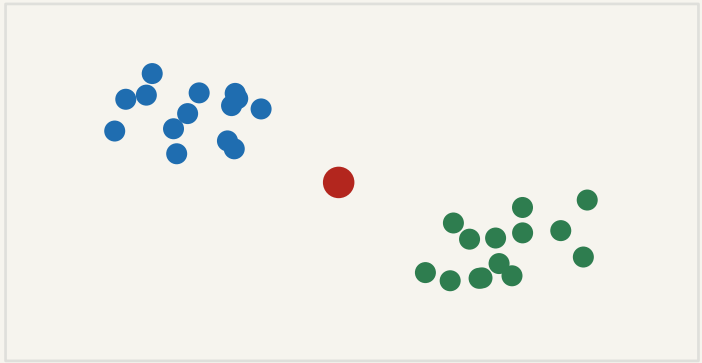
PUNTUAL



**Un valor extremo**

Un incidente abierto 300 días.

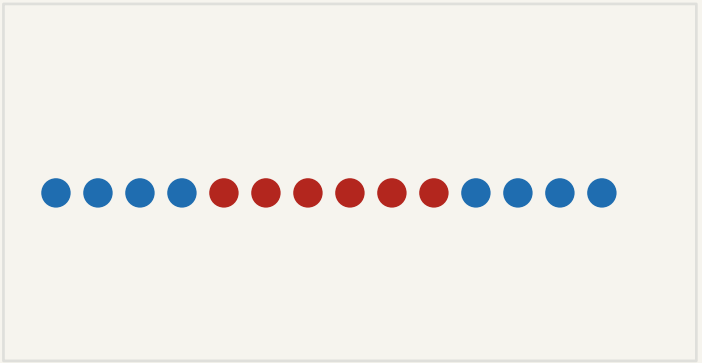
CONTEXTUAL



**Raro en su contexto**

Un incidente de «rutina» que tarda 3 días.

COLECTIVA



**Normales que, juntos, son raros**

Cien inicios de sesión fallidos seguidos.

ANÓMALO NO SIGNIFICA MALICIOSO

Puede ser un ataque, un error, un caso legítimo excepcional o un dato mal registrado. El detector señala **dónde mirar**; decide una persona.

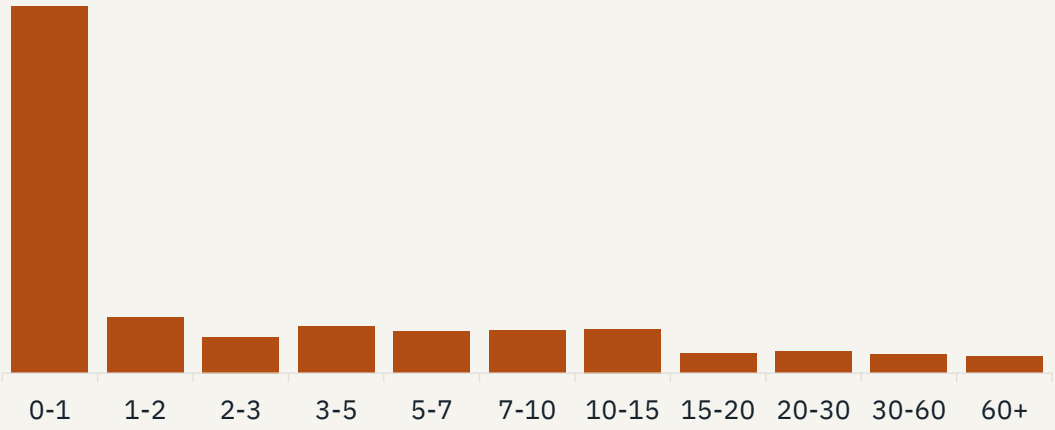
# Lo «normal» casi nunca es una campana

## LO QUE SUPONE LA REGLA: UNA CAMPANA



**Regla: «media ± 3 desviaciones»**

## LO QUE PASA DE VERDAD: DÍAS HASTA RESOLVER



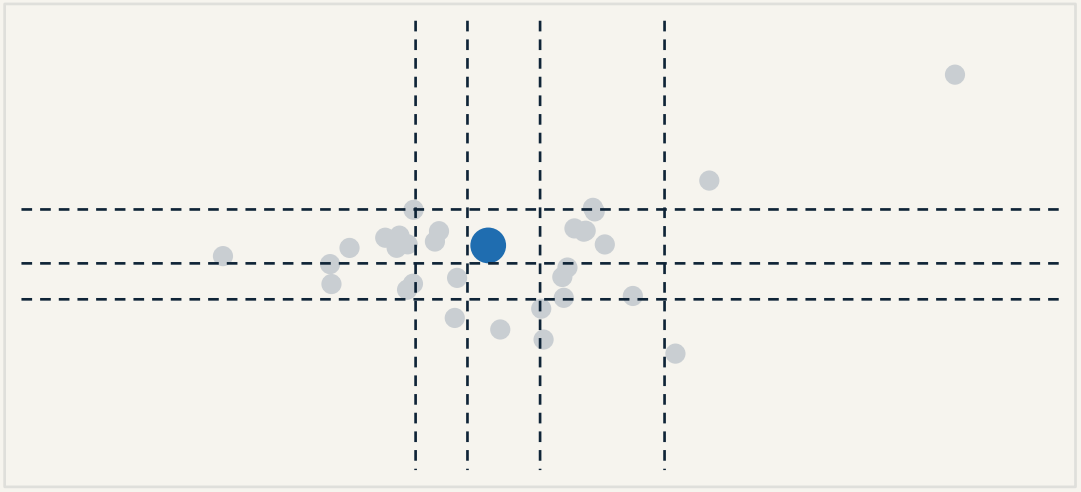

Días (intervalos desiguales) · 23.360 incidentes · media 7,4 · desviación 22,2

### DOS PROBLEMAS DE LA REGLA

Los extremos **inflan la desviación** y el límite queda altísimo; y **mira una sola variable**. Sobre anomalías que fabricamos, esa regla encuentra el 3 %.

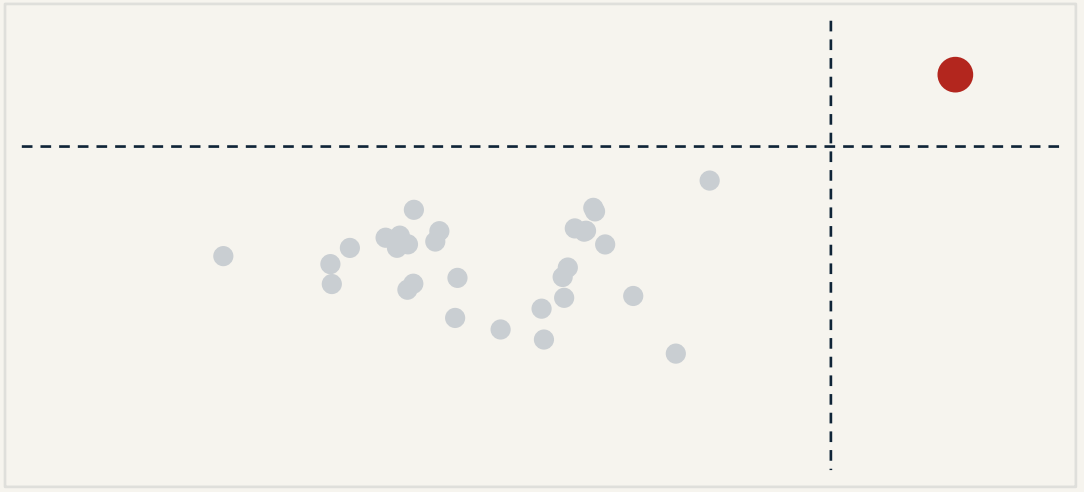
# Isolation Forest: aislar al raro con preguntas al azar

UN CASO COMÚN



**Muchas** preguntas para dejarlo solo.

UN CASO RARO

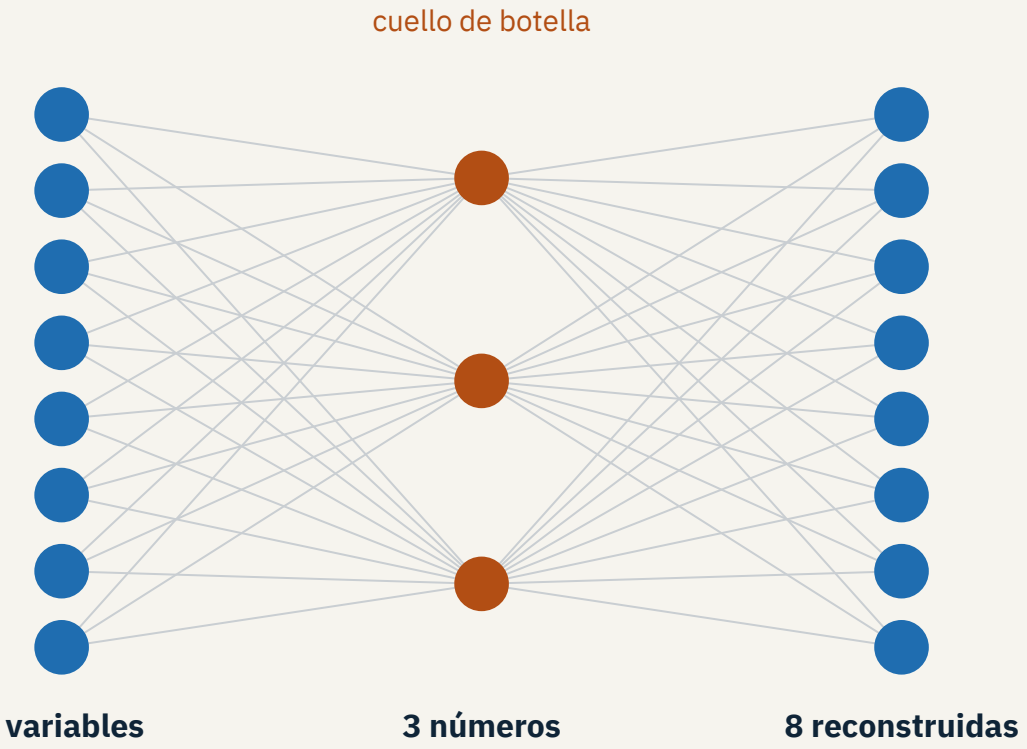


**Muy pocas** preguntas para aislarlo.

LA REGLA

Menos preguntas para aislarlo = **más anómalo**. Usa cientos de árboles de preguntas al azar y promedia; no dice *por qué* algo es raro.

# Autoencoder y otros detectores




EL PUNTAJE

Lo común se reconstruye bien; lo raro, mal: **el error de reconstrucción es el puntaje**.

OTROS DETECTORES

- **LOF**: compara la densidad local de un punto con la de sus vecinos.
- **One-Class SVM**: aprende la frontera de lo normal.

CADA DETECTOR DEFINE «RARO» A SU MANERA

En la práctica, *Isolation Forest* y el autoencoder coinciden en menos de un tercio de lo que marcan.

# ¿Cómo saber si un detector funciona sin respuestas?

## 1

### Inyectar anomalías conocidas

Fabricamos 200 incidentes raros, los mezclamos y vemos cuántos se atrapan.

**Límite:** Solo mide lo que fabricamos.

## 2

### Un indicador indirecto

Si lo marcado incumple el plazo mucho más que el promedio, es buena señal (sin usar ese dato para detectar).

**Límite:** No es lo mismo que «anómalo».

## 3

### Revisión humana

Un analista mira los marcados y dice cuántos valían la pena.

**Límite:** La más honesta y la más cara.

Y UNA CUARTA COSA: EL CORTE

«¿Cuántos revisamos?» lo decide el negocio. En una puesta en marcha real se empieza por la tercera: se muestran los 20 primeros a un analista.

PRÁCTICA 4 · 26 MINUTOS

# Práctica 4: detección de anomalías

LA PREGUNTA

## ¿Qué incidentes se comportan de forma rara?

LOS DATOS

El mismo registro, **una fila por incidente**. Detectores: regla simple, *Isolation Forest* y autoencoder.

Practica_4_Anomalias.ipynb
github.com/lsandinop/analitica-procesos-ciberseguridad

1 **Regla simple** → 2 **Isolation Forest** → 3 **Autoencoder** → 4 **Evaluar sin etiquetas** → 5 **¿Cuánto revisar?** → 6 **«Raro para su grupo»**

EL CIERRE MÁS IMPORTANTE

Sección 7: lo raro **depende del contexto**. Comparar a un incidente con los de su propio grupo es la idea central de UEBA.

APLICACIONES · EL MAPA

# Cada técnica, en qué parte del trabajo de seguridad

| APLICACIÓN | QUÉ DATOS USA | TÉCNICA | PRÁCT. |
|---|---|---|---|
| **Triaje de alertas e incidentes** | Alertas, detectores, tácticas, historial | Clasificación | 1 |
| **Priorizar vulnerabilidades** | Características y señales de explotación | Clasificación / regresión | 1 |
| **Auditar el proceso de respuesta** | Registro de eventos de incidentes | Minería de procesos | 2 |
| **Perfiles de usuarios, cuentas y activos** | Actividad agregada | Segmentación | 3 |
| **Comportamiento anómalo (UEBA)** | Actividad por usuario, dispositivo o cuenta | Anomalías | 4 |
| **Fraude y toma de cuentas** | Transacciones y sesiones | Anomalías y clasificación | 1 y 4 |
| **Tráfico de red sospechoso** | Flujos de red | Clasificación y anomalías | 1 y 4 |
| **Asistentes de IA generativa** | Texto: alertas, registros, código | Modelos de lenguaje | Curso de texto |

Preguntas para un proveedor: **¿qué datos usa?, ¿con qué lo evaluaron?, ¿qué pasa con un cliente nuevo?**

APLICACIONES · SOC

# SOC: triaje y priorización, con datos reales

GUIDE · MICROSOFT

## Triaje con etiqueta de analista

Cerca de **1 millón de incidentes reales** de más de 6.100 organizaciones, con la etiqueta de un analista (19 % verdadero positivo, 35 % falso positivo, 46 % positivo benigno).

Se publicó para entrenar y comparar modelos de triaje; se mide con *F1* promedio.

EPSS · FIRST

## ¿Qué vulnerabilidad se explotará?

Un modelo que estima, cada día, la **probabilidad de que una vulnerabilidad se explote en los próximos 30 días**. Versión 4: marzo de 2025.

Solo una minoría se explota (según FIRST, entre 2,5 % y 3 % de las CVE publicadas): por eso priorizar importa.

MITRE ATT&CK

## El «idioma común» de las técnicas

Catálogo común de tácticas y técnicas de ataque. Versión 19 (abril de 2026): 15 tácticas y 222 técnicas en el dominio empresarial.

Los datos de GUIDE usan nombres de versiones anteriores.

EL LÍMITE

En GUIDE, lo «benigno» lo decide **cada organización**: un modelo entrenado con clientes ya vistos no generaliza igual a un cliente nuevo.

APLICACIONES · IDENTIDAD

# Identidad, fraude y comportamiento

### QUÉ SE INTENTA

Detectar movimiento lateral, escalamiento de privilegios, descargas masivas o toma de cuentas.

Comparar cada usuario con **su propio comportamiento y con el de su grupo**.

### TÉCNICAS

*Isolation Forest* y autoencoders.

Perfiles de comportamiento (UEBA).

### LÍMITES

Muchos falsos positivos si el «normal» no está bien definido.

El comportamiento **cambia**: nuevo cargo, nuevo horario.

Anómalo ≠ malicioso.

LA IDEA DE LA PRÁCTICA 4

Comparar con el **grupo de pertenencia** separa un detector útil de uno que no deja de alarmar (diapositivas 64 y 69).

# Red y endpoint

### QUÉ SE INTENTA

Reconocer tráfico malicioso, por ejemplo exfiltración por túneles DNS o conexiones de malware, en el flujo de paquetes.

Datos: flujos de red, DNS y procesos.

### DATOS PARA PRACTICAR

**IoT-23**: tráfico etiquetado de malware y de dispositivos de internet de las cosas (licencia CC BY).

### EL LÍMITE

Los modelos de laboratorio suelen **caer mucho** cuando la red real es distinta de la del entrenamiento.

### LA PREGUNTA AL PROVEEDOR

¿Con qué red lo probaron? Lo que funciona con la red de un laboratorio puede no servir en la suya.

# IA generativa y la seguridad de la propia IA

USOS EN EL SOC

## Siempre con una persona que revisa

Resumir alertas.

Traducir preguntas a consultas (SPL, KQL, SQL).

Explicar scripts ofuscados.

Redactar borradores de *playbooks*.

RIESGOS ESPECÍFICOS

## El texto que el asistente lee lo escribe el atacante

**Alucinación**.

**Inyección de instrucciones**: un correo o un log con órdenes para el asistente.

**Fuga de datos** al pegar información sensible.

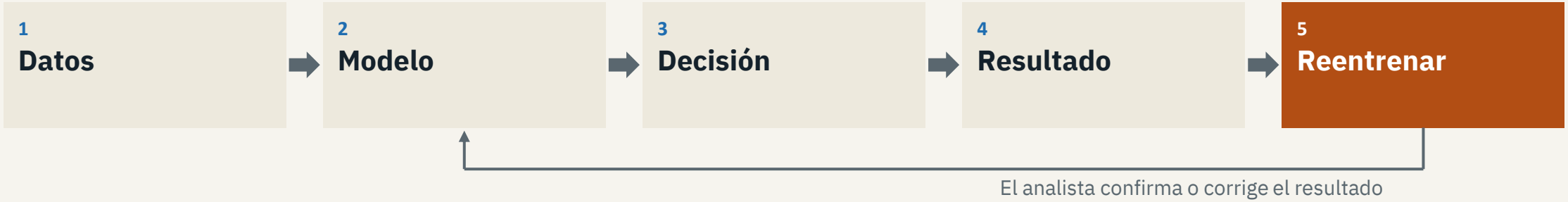
**Dependencia** de un servicio externo.

UN DATO DE NUESTRO TALLER DE TEXTO

Una frase escondida en un phishing hizo que un modelo lo clasificara como **legítimo**. Una defensa sencilla funcionó en ese caso, pero **un ejemplo no demuestra que sea segura**.

MLOPS · MANTENER EL MODELO

# Un modelo no se entrega, se mantiene




VIGILAR 1

**Datos de entrada**

¿Cambió el formato de un registro? ¿Dejó de llegar una fuente?

VIGILAR 2

**Deriva de datos**

Cambian los datos que entran: software nuevo, otra época, otra campaña.

VIGILAR 3

**Deriva del concepto**

Cambia la relación entre datos y resultado: los atacantes cambian de táctica.

VIGILAR 4

**Rendimiento real**

¿Suben las falsas alarmas? ¿Se escapan ataques? Se mide con la etiqueta que el analista pone después.

VIGILAR 5

**La versión**

Qué modelo, entrenado con qué datos, tomó cada decisión.

MLOPS · MACHINE LEARNING OPERATIONS

Las prácticas para poner modelos en producción y **mantenerlos** funcionando.

# Límites y riesgos que hay que decir en voz alta

## 1

### Cifras optimistas

Una partición al azar sobreestima: hay que probar como se va a usar.

## 2

### Atajos

El modelo puede aprender una pista que no es el fenómeno: un nombre, una plantilla, un cliente.

## 3

### Deriva

Los procesos y los ataques cambian: el modelo se degrada y hay que reentrenarlo.

## 4

### Adversarios

Quien ataca puede adaptarse a lo que el modelo mira.

## 5

### Privacidad

Los registros describen a personas: protección de datos en Colombia (Constitución art. 15, Ley 1581 de 2012, Decreto 1074 de 2015) y minimización.

## 6

### Explicabilidad

Una decisión que afecta a una persona debe poder justificarse.

*Es lo que separa un proyecto serio de una demostración vistosa.*

# Lo que se llevan: seis ideas

## 1

### Las preguntas definen la técnica

¿Hay respuesta correcta en mis datos? ¿Importan el orden y el tiempo?

## 2

### Variables y datos pesan más que el algoritmo

Escoger bien qué ve el modelo es la mitad del trabajo.

## 3

### Lo simple primero

Árbol o regresión logística; luego, si hace falta, algo más complejo.

## 4

### La exactitud engaña

Línea base, recall de lo que importa y costo de cada error.

## 5

### Cómo mides decide lo que crees saber

Al azar, por tiempo o por grupo.

## 6

### Anómalo no es malicioso

Y explicable no es lo mismo que correcto.

CIERRE · CÓMO SEGUIR

# Gracias

1 **Repite una práctica con tus propios datos**
Un registro de incidentes real de tu organización. Quita antes los datos personales.

2 **Lee el anexo de fuentes**
Para ir más a fondo en cada técnica.

3 **Vuelve con preguntas**
¿Qué le preguntarías a un registro de tu trabajo?

github.com/lsandinop/analitica-procesos-ciberseguridad

Laura Sandino Perdomo

# Glosario de términos

**Actividad** — Un paso de un proceso (por ejemplo, «Resuelto»)

**Actividad esperada** — Etiqueta de las prácticas: pasó algo real pero normal o autorizado (en un SOC, *positivo benigno*)

**Alerta** — Un aviso de un detector; un solo aviso

**Amenaza real** — Etiqueta de las prácticas: un ataque de verdad (en un SOC, *verdadero positivo*)

**Analítica aumentada** — Usar IA para ayudar a preparar datos, encontrar hallazgos y consultar

**Anomalía** — Un caso que no se parece a lo habitual

**Aprendizaje automático (ML)** — Que un sistema aprenda de ejemplos en vez de seguir reglas escritas

**Aprendizaje profundo** — ML con redes neuronales de muchas capas

**Autoencoder** — Red que comprime y reconstruye datos; se usa para detectar anomalías

**Caso** — Una instancia de un proceso, de principio a fin (un incidente)

**Calibración** — Que una probabilidad sea creíble: de los casos a los que el modelo da 30 %, más o menos el 30 % ocurre

**Clase desbalanceada** — Cuando una etiqueta es muy rara frente a las demás (por ejemplo, las amenazas reales)

**Clasificación** — Elegir una etiqueta de una lista para cada caso

**Clustering / segmentación** — Agrupar casos parecidos sin etiquetas

**Conformidad** — Qué tanto el proceso real sigue el esperado

**Deriva** — Cambio en los datos o en el mundo que degrada un modelo con el tiempo

# Glosario de términos

**Época** — Una pasada de una red neuronal por todos los datos de entrenamiento

**Estandarizar** — Pasar variables a una escala común

**Etiqueta (variable objetivo)** — La respuesta que se quiere predecir

**Evento** — Un paso concreto de un caso, con fecha y hora

**Exactitud** — Proporción de casos que acertó

**Falso negativo** — Un ataque que no se detectó

**Falso positivo** — Una alarma que no era un ataque

**Fatiga de alertas** — Cansancio por demasiadas falsas alarmas

**F1** — Una cifra que combina precisión y *recall*

**Fuga de información** — Que el modelo vea, sin querer, la respuesta o información del futuro

**Fitness** — Qué parte del comportamiento real reproduce un modelo de proceso

**Gradient boosting** — Muchos árboles pequeños en cadena, cada uno corrige al anterior

**Incidente** — Un conjunto de alertas relacionadas

**Isolation Forest** — Detector de anomalías que mide qué tan fácil es aislar un caso

**K-means** — Algoritmo de segmentación con k grupos

**Línea base** — Lo que acertaría un modelo que no mira los datos

# Glosario de términos

**Matriz de confusión** — Tabla de aciertos y errores por tipo

**MTTD / MTTR** — Tiempo medio de detección / de respuesta

**Overfitting (sobreajuste)** — Memorizar el entrenamiento y fallar con casos nuevos

**Pesos de clase** — Hacer que un error en la clase rara cuente más al entrenar

**Positivo benigno** — Algo real pero esperado o autorizado

**Precisión** — De los casos marcados como positivos, cuántos lo eran

**Recall (exhaustividad)** — De los positivos que había, cuántos encontró

**Registro de eventos** — Tabla con caso, actividad y fecha de cada paso

**Sin amenaza** — Etiqueta de las prácticas: la alerta sonó, pero no pasaba nada malo (en un SOC, *falso positivo*)

**Sobremuestreo / submuestreo** — Copiar o inventar casos de la clase rara / quitar casos de la clase común

**SIEM / EDR / SOAR** — Reúne y alerta / vigila equipos / automatiza respuesta

**SLA** — Plazo acordado para resolver algo

**SOC** — Centro de operaciones de seguridad

**Variable (característica)** — Una columna que describe cada caso

**Variante** — Un camino completo y repetido en un proceso

# Glosario de siglas

**ACM** — Association for Computing Machinery (asociación de computación; organiza la ACM Web Conference)

**AGPL** — GNU Affero General Public License (licencia de software libre)

**ARI** — Adjusted Rand Index (índice de Rand ajustado: mide qué tanto coinciden dos agrupaciones; 1 = idénticas)

**CatBoost** — Categorical Boosting (librería de gradient boosting)

**CC BY** — Creative Commons Attribution (licencia que pide citar al autor)

**CNN** — Convolutional Neural Network (red neuronal convolucional)

**Colab** — Google Colaboratory (cuadernos de Python en el navegador)

**CRISP-DM** — Cross-Industry Standard Process for Data Mining (proceso estándar de la industria para minería de datos)

**CVE** — Common Vulnerabilities and Exposures (catálogo de vulnerabilidades conocidas)

**DBSCAN** — Density-Based Spatial Clustering of Applications with Noise (agrupación por densidad)

**DNS** — Domain Name System (sistema de nombres de dominio)

**EDR** — Endpoint Detection and Response (detección y respuesta en los equipos)

**EPSS** — Exploit Prediction Scoring System (sistema de puntuación de la probabilidad de explotación)

**F1** — F1 score: medida que combina precisión y recall (media armónica); no es una sigla

**FIRST** — Forum of Incident Response and Security Teams (foro de equipos de respuesta a incidentes)

**FN** — Falso negativo (abreviatura usada en estas diapositivas)

**FP** — Falso positivo (abreviatura usada en estas diapositivas)

**GPT** — Generative Pre-trained Transformer (transformer generativo preentrenado)

# Glosario de siglas

**GUIDE** — Nombre del conjunto de datos de Microsoft sobre incidentes de seguridad (en Kaggle: «Microsoft Security Incident Prediction»); el artículo es «AI-Driven Guided Response for Security Operation Centers»

**IA** — Inteligencia artificial (AI, en inglés)

**ICDM** — IEEE International Conference on Data Mining (congreso de minería de datos)

**IEEE** — Institute of Electrical and Electronics Engineers (instituto de ingenieros eléctricos y electrónicos)

**IoT** — Internet of Things (internet de las cosas)

**KQL** — Kusto Query Language (lenguaje de consulta de Microsoft)

**LightGBM** — Light Gradient Boosting Machine (librería de gradient boosting)

**LLM** — Large Language Model (modelo de lenguaje grande)

**LOF** — Local Outlier Factor (factor de valor atípico local)

**LSTM** — Long Short-Term Memory (memoria larga a corto plazo; red para secuencias)

**MITRE ATT&CK** — Adversarial Tactics, Techniques, and Common Knowledge (catálogo de tácticas y técnicas de ataque, de la organización MITRE)

**ML** — Machine Learning (aprendizaje automático)

**MLOps** — Machine Learning Operations (operaciones de aprendizaje automático: poner modelos en producción y mantenerlos)

**MLP** — Multilayer Perceptron (perceptrón multicapa: red neuronal para datos en tabla)

**MTTD** — Mean Time To Detect (tiempo medio de detección)

**MTTR** — Mean Time To Respond (tiempo medio de respuesta; a veces se lee como recuperación o resolución)

**NDR** — Network Detection and Response (detección y respuesta en la red)

**NeurIPS** — Conference on Neural Information Processing Systems (congreso de aprendizaje automático)

# Glosario de siglas

**PB** — Positivo benigno (abreviatura usada en estas diapositivas)

**PCA** — Principal Component Analysis (análisis de componentes principales)

**PM4Py** — Process Mining for Python (librería de minería de procesos)

**ProM** — Process Mining framework (herramienta académica de minería de procesos)

**SHAP** — SHapley Additive exPlanations (explicaciones aditivas de Shapley)

**SIEM** — Security Information and Event Management (gestión de información y eventos de seguridad)

**SLA** — Service Level Agreement (acuerdo de nivel de servicio: el plazo acordado para resolver)

**SOAR** — Security Orchestration, Automation and Response (orquestación, automatización y respuesta de seguridad)

**SOC** — Security Operations Center (centro de operaciones de seguridad)

**SPL** — Search Processing Language (lenguaje de consulta de Splunk)

**SQL** — Structured Query Language (lenguaje de consulta de bases de datos)

**SVM** — Support Vector Machine (máquina de vectores de soporte)

**TI** — Tecnologías de la información

**UEBA** — User and Entity Behavior Analytics (analítica del comportamiento de usuarios y entidades)

**VN** — Verdadero negativo (abreviatura usada en estas diapositivas)

**VP** — Verdadero positivo (abreviatura usada en estas diapositivas)

**XGBoost** — eXtreme Gradient Boosting (librería de gradient boosting)

ANEXO · LISTA DE VERIFICACIÓN

# Antes de creerle a una cifra, pregunta

1. ¿Cuál es la **línea base**?
2. ¿Cómo se **partieron** los datos (azar, tiempo, grupo)? ¿Es la forma en que se usará?
3. ¿Hay casos **casi idénticos** a ambos lados?
4. ¿Qué dice el **recall de la clase que importa**, no solo la exactitud?
5. ¿Qué cuesta cada tipo de error?
6. ¿Se tocó la **prueba** para ajustar algo?
7. ¿Alguna variable **contiene la respuesta** o información del futuro?
8. ¿Cuántos casos tiene la prueba? Con pocos, la cifra tiene un margen de error grande.
9. ¿Se probó con un **caso nuevo** (cliente, periodo, red)?
10. ¿Quién **revisó** lo que el modelo marcó?

# Fuentes: datos, seguridad y herramientas

## DATOS Y CONJUNTOS

- Freitas, Kalajdjieski, Gharib y McCann (2025). *AI-Driven Guided Response for Security Operation Centers with Microsoft Copilot for Security.* ACM Web Conference 2025, pp. 191-200. Conjunto GUIDE, Kaggle, licencia CDLA-Permissive-2.0.
- Amaral, Fantinato, Reijers y Peres (2018). *Incident management process enriched event log.* UCI Machine Learning Repository, doi 10.24432/C57S4H. CC BY 4.0.
- Aposemat IoT-23 (Stratosphere Laboratory, CTU Praga). CC BY 4.0.

## SEGURIDAD

- FIRST, *Exploit Prediction Scoring System (EPSS)*, versión 4 (17 de marzo de 2025); tasa de explotación observada: 2,5 % a 3 % de las CVE publicadas.
- MITRE ATT&CK, versión 19 (abril de 2026).
- MinTIC y ColCERT, indicadores de compromiso en datos abiertos y estadísticas de incidentes de seguridad digital de 2025.
- Protección de datos en Colombia: Constitución Política, art. 15; Ley 1581 de 2012; Decreto 1377 de 2013 (compilado en el Decreto 1074 de 2015); Ley 1273 de 2009, art. 269F; Decreto 0769 de 2026 (menores de edad en entornos digitales).

## HERRAMIENTAS

- PM4Py (licencia AGPL-3.0) · scikit-learn · pandas · matplotlib.

# Fuentes: conceptos y métodos


- Gartner, *Analytics Ascendancy Model* (descriptiva, diagnóstica, predictiva, prescriptiva) y *augmented analytics* (2017).
- IEEE Task Force on Process Mining (2011). *Process Mining Manifesto.*
- Buijs, van Dongen y van der Aalst (2012). *On the role of fitness, precision, generalization and simplicity in process discovery.*
- Breiman (2001). *Random Forests.* · Friedman (2001). *Greedy function approximation: a gradient boosting machine.* · Chen y Guestrin (2016). *XGBoost.*
- Liu, Ting y Zhou (2008). *Isolation Forest.* ICDM.
- Lin, Dai y Liu (2026). *On Probability Estimation for Unbalanced Classification.* Journal of Statistical Theory and Practice, 20:57. · Chawla, Bowyer, Hall y Kegelmeyer (2002). *SMOTE: Synthetic Minority Over-sampling Technique.* JAIR, 16.
- Rousseeuw (1987). *Silhouettes.* · Lundberg y Lee (2017). *A Unified Approach to Interpreting Model Predictions (SHAP).*
- Rumelhart, Hinton y Williams (1986). *Learning representations by back-propagating errors.* · Hochreiter y Schmidhuber (1997). *Long Short-Term Memory.* · Vaswani et al. (2017). *Attention Is All You Need.*
- Grinsztajn, Oyallon y Varoquaux (2022). *Why do tree-based models still outperform deep learning on typical tabular data?* NeurIPS.
- Sculley et al. (2015). *Hidden Technical Debt in Machine Learning Systems.* NeurIPS.
- CRISP-DM (Cross-Industry Standard Process for Data Mining), 1999.